D1-Q416: Risk Appetite vs Risk Tolerance

Question

Which statement BEST distinguishes risk appetite from risk tolerance?

A. Appetite is a measurable limit; tolerance is a broad statement

B. Appetite is the amount of risk the enterprise is willing to accept; tolerance is the acceptable variation around that appetite

C. Appetite applies only to financial risk; tolerance applies to operational risk

D. Appetite is set by the CRO; tolerance is set by regulators

D1-Q416: Answer

Correct Answer: B

Appetite is the broad willingness to accept risk in pursuit of objectives. Tolerance translates appetite into specific, measurable limits of acceptable variation for individual risk categories.

D1-Q417: Risk Capacity vs Risk Appetite

Question

Which concept represents the maximum risk an enterprise can absorb before its existence is threatened?

- A Risk appetite
- B Risk tolerance
- C Risk capacity
- D Risk acceptance

D1-Q417: Answer

Correct Answer: C — Risk capacity

Risk capacity is the maximum risk the enterprise can survive. It is always greater than or equal to appetite; breaching capacity threatens viability.

D1-Q418: Board Accountability for Risk

Question

Who is ultimately accountable to shareholders for enterprise risk management?

A. Chief risk officer
B. Board of directors
C. Internal audit
D. Risk management department

D1-Q418: Answer

Correct Answer: B

The board of directors is ultimately accountable to shareholders, customers, employees, and the public for enterprise risk management.

D1-Q419: Risk Appetite Communication

Question

What is the MOST effective way to communicate risk appetite to operational staff?

A. Email the full appetite statement once a year

B. Translate appetite into operational tolerances, thresholds, and decision rules

C. Discuss it only in executive meetings

D. Post it on the intranet without explanation

D1-Q419: Answer

Correct Answer: B

Operational staff need concrete tolerances, thresholds, and decision rules derived from appetite so they can make risk-aware decisions in daily work.

D1-Q420: Three Lines of Defense - First Line

Question

Which activity is a FIRST line of defense responsibility?

A. Independent assurance on internal controls
B. Operational risk management and control implementation
C. Establishing the enterprise risk framework
D. Board oversight of risk appetite

D1-Q420: Answer

Correct Answer: B

The first line (operational management) owns risk and implements controls. The second line establishes the framework; the third line provides independent assurance.

D1-Q421: Three Lines of Defense - Second Line

Question

Which is a SECOND line of defense activity?

A. Performing day-to-day controls
B. Risk oversight, framework development, and compliance monitoring
C. Internal audit testing
D. Board risk committee meetings

D1-Q421: Answer

Correct Answer: B

The second line provides risk oversight, develops frameworks, monitors compliance, and challenges the first line. Internal audit is the third line.

D1-Q422: Three Lines of Defense - Third Line

Question

What is the PRIMARY role of the third line of defense?

- A Implement controls
- B Establish risk appetite
- C Provide independent assurance on governance, risk, and control
- D Approve risk treatment plans

D1-Q422: Answer

Correct Answer: C

The third line—internal audit—provides independent, objective assurance on the effectiveness of governance, risk management, and internal controls.

D1-Q423: Risk Governance Failures

Question

Which is the MOST common cause of risk governance failures?

A. Insufficient risk management software
B. Unclear accountability and weak oversight
C. Too many risk assessments performed
D. Excessive regulatory guidance

D1-Q423: Answer

Correct Answer: B

Governance failures typically stem from unclear accountability, weak oversight, and poorly defined roles—not tooling or assessment frequency.

D1-Q424: Blame Culture Inhibitor

Question

Which is the MOST effective inhibitor of relevant risk communication in an enterprise?

- A Lack of advanced tools
- B A blame culture that discourages reporting
- C Too many risk reports
- D Excessive regulation

D1-Q424: Answer

Correct Answer: B

A blame culture suppresses open reporting and escalation, making it the single most damaging inhibitor of effective risk communication.

D1-Q425: Risk Culture Symptom

Question

Which is a symptom of a problematic risk culture?

- A Open communication about risk
- B Overconfidence in the ability to manage risk
- C Clear understanding of risk appetite
- D Regular risk reporting to management

D1-Q425: Answer

Correct Answer: B

Overconfidence, dismissal of risk findings, and resistance to challenge are classic symptoms of a weak risk culture.

D1-Q426: Risk Policy Hierarchy

Question

Which document BEST expresses the high-level intent of an organization's security practices?

- A Procedures
- B Policies
- C Guidelines
- D Standards

D1-Q426: Answer

Correct Answer: B — Policies

Policies express management intent at a high level. Procedures are detailed steps; standards are measurable requirements; guidelines are recommendations.

D1-Q427: Risk Awareness Primary Focus

Question

What is the PRIMARY consideration when developing an IT risk awareness program?

A. Why IT owns technology risk
B. How technology risk impacts each attendee's business area
C. How to transfer technology risk
D. Why technology risk is harder than other risks

D1-Q427: Answer

Correct Answer: B

Stakeholders must understand how IT-related risk affects their specific business area and objectives. IT does not own technology risk; the business does.

D1-Q428: Governance Accountability Principle

Question

Which principle is MOST fundamental to good governance?

A. Centralizing all decisions with the CIO
B. Clear accountability aligned with authority
C. Outsourcing all risk decisions
D. Eliminating all risk

D1-Q428: Answer

Correct Answer: B

Accountability must align with authority. Without this alignment, accountability is unenforceable and governance breaks down.

D1-Q429: Risk Register Ownership

Question

Who should own the enterprise risk register?

A. The internal audit team

B. The risk management function, with input from risk owners

C. The IT department alone

D. An external consultant

D1-Q429: Answer

Correct Answer: B

The risk management function typically maintains the register, with risk owners providing and validating entries for their areas.

D1-Q430: Risk Appetite Revision

Question

Who should approve changes to the enterprise risk appetite?

A. Risk management department

B. Board of directors with senior management input

C. Individual business unit managers

D. Internal audit

D1-Q430: Answer

Correct Answer: B

Risk appetite is a board-level decision informed by senior management, reflecting the enterprise's strategic direction and tolerance.

D1-Q431: Risk Governance and Strategy

Question

How should risk governance relate to business strategy?

- A Risk governance should be independent and unrelated
- B Risk governance should enable strategy by managing risks to objectives
- C Risk governance should block strategic change
- D Risk governance should replace strategic planning

D1-Q431: Answer

Correct Answer: B

Risk governance enables strategy by ensuring risks to objectives are identified, assessed, and managed within appetite—not by blocking change.

D1-Q432: Board Risk Reporting

Question

Which characteristic makes risk reporting MOST useful to the board?

- A Inclusion of every identified risk
- B Aggregated exposures against appetite with clear trends
- C Use of technical jargon
- D Weekly frequency

D1-Q432: Answer

Correct Answer: B

Boards need aggregated, trend-oriented views against appetite—not exhaustive detail—to provide strategic oversight.

D1-Q433: Risk Culture and Incentives

Question

How do incentive structures influence risk culture?

- A They have no effect
- B They align behavior with desired risk-taking boundaries
- C They eliminate the need for policies
- D They prevent all incidents

D1-Q433: Answer

Correct Answer: B

Well-aligned incentives reward appropriate risk-taking and discourage recklessness. Misaligned incentives undermine even the best controls.

D1-Q434: Risk Governance Maturity

Question

Which characteristic indicates a mature risk governance structure?

- A Risk is managed only after incidents
- B Risk is integrated into strategic planning and decision-making
- C Risk is managed exclusively by the risk department
- D Risk reports are annual compliance artifacts

D1-Q434: Answer

Correct Answer: B

Mature governance integrates risk into strategy, budgeting, and operations. Reactive or siloed risk management indicates lower maturity.

D1-Q435: Third-Party Governance

Question

Which is MOST important for enterprise-level third-party risk governance?

- (A) Delegating oversight to the vendor
- (B) A centralized third-party risk program with clear accountability
- (C) Annual contract reviews only
- (D) Relying on vendor self-assessments

D1-Q435: Answer

Correct Answer: B

A centralized program ensures consistent due diligence, contracting, monitoring, and termination practices across all third parties.

D1-Q436: Risk Governance and Risk Aggregation

Question

Why is risk aggregation important for enterprise governance?

- (A) It eliminates the need for business-unit risk registers
- (B) It provides a holistic view of exposures that may exceed appetite
- (C) It ensures every risk has a unique owner
- (D) It replaces risk assessment

D1-Q436: Answer

Correct Answer: B

Aggregation reveals concentrations and cumulative exposures that may individually appear acceptable but collectively exceed appetite—critical for board oversight.

D1-Q437: Governance and Regulatory Integration

Question

What is the BEST way to integrate regulatory requirements into risk governance?

A. Treat compliance as separate from risk management

B. Map regulatory obligations to risk categories and controls within the ERM framework

C. Wait for regulators to identify gaps

D. Delegate compliance entirely to external counsel

D1-Q437: Answer

Correct Answer: B

Mapping obligations to risk categories and controls ensures compliance is managed proactively within the ERM framework—not as an isolated activity.

D1-Q438: Governance Effectiveness Measure

Question

Which is the BEST measure of risk governance effectiveness?

A. Number of policies published
B. Degree to which risk-informed decisions are made and evidenced
C. Size of the risk management department
D. Frequency of risk committee meetings

D1-Q438: Answer

Correct Answer: B

Effectiveness is measured by whether risk information actually informs decisions—not by documentation volume, headcount, or meeting frequency.

D1-Q439: Risk Reporting Frequency

Question

What is the BEST approach for determining risk reporting frequency to senior management?

A. Always monthly
B. Aligned with the pace of change and criticality of reported risks
C. Only annually
D. Only after incidents

D1-Q439: Answer

Correct Answer: B

Frequency should reflect how rapidly the risk environment changes and how critical those risks are to business objectives.

D1-Q440: Governance and Emerging Risk

Question

How should emerging risk be governed at the enterprise level?

- A. Ignore until it becomes a realized loss
- B. Establish a process for identifying, assessing, and escalating emerging risk
- C. Delegate entirely to IT
- D. Report only to external auditors

D1-Q440: Answer

Correct Answer: B

A structured process for identifying, assessing, and escalating emerging risk enables proactive management before issues crystallize into material losses.

D2-Q441: Risk Assessment Objectives

Question

What is the PRIMARY objective of a risk assessment?

- A To document every possible risk
- B To identify and evaluate risk to enable risk-aware decisions
- C To eliminate all risk
- D To satisfy auditors

D2-Q441: Answer

Correct Answer: B

Risk assessment identifies and evaluates risk and its potential effects to enable informed, risk-aware decision-making.

D2-Q442: Asset Identification First

Question

What is the FIRST step in the risk assessment process?

- A Identify threats
- B Identify assets
- C Identify vulnerabilities
- D Identify threat sources

D2-Q442: Answer

Correct Answer: B

Asset identification comes first—you cannot assess risk to what you have not identified. Threats and vulnerabilities follow.

D2-Q443: Risk Scenario Analysis Purpose

Question

Risk scenarios are analyzed to determine:

A. Strength of controls
B. Likelihood and impact
C. Current risk profile
D. Root cause

D2-Q443: Answer

Correct Answer: B

Risk scenarios describe events that can lead to business impact and are evaluated for likelihood and impact should the event occur.

D2-Q444: Risk Register Content

Question

Which information is ESSENTIAL for each risk in a risk register?

- A Date, description, impact, probability, score, mitigation, owner
- B Date, description, cost, communication plan, owner
- C Description, cost, owner
- D Risk, controls, audit trail

D2-Q444: Answer

Correct Answer: A

A complete register entry includes date, description, impact, probability, risk score, mitigation action, and owner.

D2-Q445: Quantitative Risk Analysis Drawback

Question

The MOST significant drawback of quantitative risk analysis vs. qualitative is:

A. Lower objectivity
B. Greater reliance on expertise
C. Less management buy-in
D. Higher cost

D2-Q445: Answer

Correct Answer: D

Quantitative analysis is more complex and costly, requiring reliable data and statistical effort.

D2-Q446: Statistical Methods in Risk Analysis

Question

Deriving likelihood and impact through statistical methods is MOST associated with:

- A Risk scenario
- B Qualitative
- C Quantitative
- D Semiquantitative

D2-Q446: Answer

Correct Answer: C

Quantitative risk analysis derives likelihood and impact from statistical methods and data.

D2-Q447: BIA Input to BCP

Question

Which is a PRIMARY input to the Business Continuity Plan?

- A RTO
- B DR test results
- C Business Impact Analysis (BIA)
- D BC test results

D2-Q447: Answer

Correct Answer: C

The BIA identifies critical processes, impacts, and recovery priorities; these outputs are the foundation for the BCP.

D2-Q448: RPO Meaning

Question

A manager confirms an application cannot lose more than four hours of data. Which objective is this?

A. MTD
B. RPO
C. RTO
D. BIA

D2-Q448: Answer

Correct Answer: B — RPO

Recovery Point Objective is the maximum acceptable data loss measured in time. Four hours of data loss = RPO of 4 hours.

D2-Q449: RTO vs MTD

Question

An application tolerates 4 hours of downtime but must be recovered within 6 hours. Which metrics are correct?

- A RPO 4h, RTO 6h
- B MTD 4h, RTO 6h
- C MTD 6h, RPO 4h
- D RTO 4h, MTD 6h

D2-Q449: Answer

Correct Answer: D

RTO is the target recovery time (4h). MTD is the maximum tolerable downtime before severe impact (6h). RTO must be less than or equal to MTD.

D2-Q450: Risk Scenario Actors

Question

Which risk scenario component has potential to generate internal or external threat?

A. Timing dimension
B. Events
C. Assets
D. Actors

D2-Q450: Answer

Correct Answer: D

Actors—internal or external, human or non-human—have the potential to generate threats.

D2-Q451: Risk Scenario Requirements

Question

What are the PRIMARY requirements for creating risk scenarios? (Choose two)

A. Potential threats and vulnerabilities
B. Determination of value of asset/business process
C. Determination of actors
D. Determination of threat type

D2-Q451: Answer

Correct Answer: A and B

Risk scenarios require understanding of (1) threats and vulnerabilities that could cause loss and (2) the value of the asset or business process at risk.

D2-Q452: Effective Risk Assessment

Question

Which is MOST effective in assessing business risk?

A. Use case analysis
B. Business case analysis
C. Risk scenarios
D. Risk plan

D2-Q452: Answer

Correct Answer: C

Risk scenarios are the most effective technique for assessing business risk—they help determine likelihood and impact of identified risks.

D2-Q453: Risk Register Preparation

Question

The preparation of a risk register begins in which risk management process?

A. Risk response planning
B. Risk monitoring and control
C. Risk management planning
D. Risk identification

D2-Q453: Answer

Correct Answer: D

The risk register is initiated during risk identification, with description, cause, probability, impact, responses, owners, and status captured.

D2-Q454: BIA Primary Use

Question

A Business Impact Analysis is PRIMARILY used to:

A. Estimate resources to resume operations
B. Evaluate impact of disruption over time
C. Calculate likelihood and impact of threats
D. Evaluate high-level business requirements

D2-Q454: Answer

Correct Answer: B

A BIA evaluates impact of disruption over time on the enterprise's ability to operate and determines urgency of each business activity.

D2-Q455: Risk Scenarios Enable Assessment

Question

Risk scenarios enable risk assessment because they:

A. Cover all potential risks
B. Minimize need for quantitative methods
C. Segregate IT from business risk
D. Help estimate frequency and impact of risk

D2-Q455: Answer

Correct Answer: D

Risk scenarios help estimate frequency and impact—the two key dimensions of risk assessment.

D2-Q456: Risk Register for Scenarios

Question

Which information in the risk register BEST helps develop proper risk scenarios? A list of:

A. Potential threats to assets
B. Residual risk
C. Accepted risk
D. Security incidents

D2-Q456: Answer

Correct Answer: A

Potential threats to assets help isolate vulnerabilities and associated risks, which form the basis of risk scenarios.

D2-Q457: Identifying Control Deficiencies

Question

Which BEST helps identify information systems control deficiencies?

- A Gap analysis
- B Current IT risk profile
- C IT controls framework
- D Countermeasure analysis

D2-Q457: Answer

Correct Answer: A

Gap analysis compares desired control objectives with actual design and effectiveness to identify control deficiencies.

D2-Q458: Continuous Monitoring Performance

Question

When assessing a critical application server, the MOST reliable assessment results come from:

A. Database auditing activation
B. Documented performance objectives
C. Continuous monitoring
D. Security module documentation

D2-Q458: Answer

Correct Answer: C

Continuous monitoring tracks key performance metrics in real time and addresses issues with minimum impact.

D2-Q459: Risk Register Update Frequency

Question

Which presents the GREATEST risk when updating the risk register? Updates are:

A. Carried out jointly
B. Carried out after incidents
C. Carried out annually
D. Subject to CISO approval

D2-Q459: Answer

Correct Answer: C

Annual-only updates mean the register does not reflect current IT risk status. It should be updated continuously as risks change.

D2-Q460: IT Risk Measurement

Question

IT risk is measured by its:

A. Damage to IT systems
B. Impact on business operations
C. Countermeasure cost
D. Annual loss expectancy

D2-Q460: Answer

Correct Answer: B

IT risk is the business risk associated with IT; it is primarily measured by its impact on business operations.

D2-Q461: Quantitative Risk Analysis Description

Question

Deriving likelihood and impact through statistical methods is BEST described as:

A. Quantitative risk analysis
B. Risk scenario analysis
C. Qualitative risk analysis
D. Probabilistic risk assessment

D2-Q461: Answer

Correct Answer: A

Quantitative risk analysis derives probability and impact from statistical methods and data.

D2-Q462: Local Mitigation Responsibility

Question

Local management has mitigated high-level risk. Who remains responsible?

A. Local management
B. Corporate CRO
C. Local purchasing manager
D. Corporate management

D2-Q462: Answer

Correct Answer: D

Corporate management remains responsible for the risk even when responses are executed at a lower organizational level.

D2-Q463: Scenario Analysis for Likelihood

Question

Which BEST estimates the likelihood of significant events affecting an enterprise?

A. Threat analysis
B. Cost-benefit analysis
C. Scenario analysis
D. Countermeasure analysis

D2-Q463: Answer

Correct Answer: C

Scenario analysis with vulnerability analysis determines whether a risk is relevant and estimates likelihood of significant events.

D2-Q464: Improving Risk Decisions

Question

Which BEST improves decision-making related to risk?

- A. Documented risk register
- B. Risk awareness training
- C. Updated security policies
- D. Department-level accountability

D2-Q464: Answer

Correct Answer: A

A documented risk register captures relevant scenarios and prioritizes risk responses, improving decision quality.

D2-Q465: Independent Risk Review Purpose

Question

The PRIMARY reason to have the risk management process reviewed by an independent professional is to:

A. Validate cost-effective solutions
B. Validate internal control weaknesses
C. Assess end-to-end process validity
D. Assess whether risk profile and factors are defined properly

D2-Q465: Answer

Correct Answer: C

An independent reviewer can assess the entire risk management process end to end without bias.

D3-Q466: Outsourced Noncore Greatest Concern

Question

Which outcome of outsourcing noncore processes is of GREATEST concern?

- A Total cost exceeds projections
- B Internal IS experience is lost
- C Vendor employees are disloyal
- D Sensitive data is subcontracted by the vendor

D3-Q466: Answer

Correct Answer: D

Subcontracting sensitive data increases cession of control—the greatest concern in third-party relationships.

D3-Q467: Business Case for Risk Treatment

Question

When proposing a risk treatment, a risk practitioner PRIMARILY uses a:

A. Technical evaluation report
B. Business case
C. Vulnerability report
D. Budgetary requirements

D3-Q467: Answer

Correct Answer: B

A business case documents the risk assessment, control costs, and expected benefits—essential for approval.

D3-Q468: Most Important for Effective Risk Management

Question

Which is MOST important for effective risk management?

- A Assigning risk owners
- B Ensuring regulatory compliance
- C Integrating risk into operations
- D Implementing risk avoidance

D3-Q468: Answer

Correct Answer: A

Assigning risk to individual owners maximizes accountability—the foundation of effective risk management.

D3-Q469: Most Important Outsourcing Question

Question

What is the MOST important question about outsourcing arrangements?

- A. Are security exception procedures in place?
- B. Are SLAs being met?
- C. Is the provider ISO certified?
- D. Are specific security controls mandated in the contract?

D3-Q469: Answer

Correct Answer: D

Without explicit security requirements in the contract, the enterprise has no assurance that the provider will comply with specific controls.

D3-Q470: Basis for Risk Ownership

Question

Which activity provides the BEST basis for establishing risk ownership?

- A Documenting interdependencies
- B Mapping risk to specific business processes
- C Reviewing RACI charts
- D Distributing risk among business owners

D3-Q470: Answer

Correct Answer: B

Mapping risk to a specific business process identifies the process owner—the natural risk owner.

D3-Q471: Risk Response Report

Question

A risk response report includes recommendations for:

A. Acceptance
B. Assessment
C. Evaluation
D. Quantification

D3-Q471: Answer

Correct Answer: A

Risk response reports recommend among the four response options: accept, mitigate, transfer, avoid.

D3-Q472: Reducing to Acceptable Risk

Question

Which is MOST likely reduced to achieve acceptable risk?

A. Risk appetite
B. Control risk
C. Residual risk
D. Inherent risk

D3-Q472: Answer

Correct Answer: C

Residual risk—the risk remaining after controls—is what must be reduced to within appetite.

D3-Q473: Denial-of-Service Decision

Question

A financial institution decides not to address a DoS vulnerability. The MOST likely reason is:

A. Countermeasure is too complex
B. Sufficient safeguards exist
C. Likelihood is unknown
D. Cost of countermeasure outweighs potential loss

D3-Q473: Answer

Correct Answer: D

The enterprise accepted the risk because the cost of mitigation exceeded the potential loss.

D3-Q474: Two-Factor Cost-Benefit

Question

Which is MOST relevant to a two-factor authentication cost-benefit analysis?

A. Approved project budget
B. Incident frequency
C. Annual loss expectancy
D. Total cost of ownership

D3-Q474: Answer

Correct Answer: D

Total cost of ownership establishes the full life-cycle cost baseline required for cost-benefit comparison.

D3-Q475: Outsourcing Contract Most Important

Question

What is the MOST important part of an outsourcing contract?

- A Right to audit
- B Provisions to assess compliance
- C Incident notification procedures
- D Encryption requirements

D3-Q475: Answer

Correct Answer: B

Without compliance assessment provisions, the enterprise cannot verify that the supplier meets its security obligations.

D3-Q476: Ambiguous SLA Risk

Question

What is the GREATEST risk when engaging a cloud provider?

A. Same geographical location
B. Ambiguous SLA
C. Missing references
D. Reliance on third-party audits

D3-Q476: Answer

Correct Answer: B

Ambiguous SLAs make it difficult to determine whether the provider meets its obligations—leaving the enterprise without recourse.

D3-Q477: Insurance for Unmitigable Risk

Question

When a risk cannot be sufficiently mitigated, the BEST option to protect financial impact is:

A. Insurance
B. Updating the register
C. Staff training
D. Outsourcing

D3-Q477: Answer

Correct Answer: A

Insurance transfers financial risk to the insurer, providing monetary compensation for impact.

D3-Q478: Cost Exceeds Benefit

Question

When mitigation cost exceeds benefit, the BEST risk response is:

A. Treat
B. Terminate
C. Accept
D. Transfer

D3-Q478: Answer

Correct Answer: C

When control cost exceeds expected loss, accepting the risk is economically rational.

D3-Q479: Risk Scenarios for Continuity

Question

Which activity MOST benefits a continuity improvement initiative?

A. Develop KRIs
B. Determine control ownership
C. Update the risk register
D. Develop IT risk scenarios

D3-Q479: Answer

Correct Answer: D

Risk scenarios link IT failures to business impact, informing continuity planning and prioritization.

D3-Q480: Reciprocal Agreement

Question

A reciprocal agreement with another company for equipment is an example of risk:

- A Transfer
- B Avoidance
- C Acceptance
- D Mitigation

D3-Q480: Answer

Correct Answer: D

Reciprocal agreements reduce impact when an event occurs—a form of risk mitigation.

D3-Q481: Selecting Risk Response

Question

Which would BEST help an enterprise select an appropriate risk response?

A. Change analysis
B. Transferable risk analysis
C. Likelihood and impact analysis
D. Control cost and benefit analysis

D3-Q481: Answer

Correct Answer: D

Cost-benefit analysis determines whether mitigation can bring risk to acceptable levels economically.

D3-Q482: Optimal Security Investment

Question

Which leads to optimal return on security investment?

A. Maximum protection on all assets
B. Focus on important assets and protect appropriately
C. Minimum protection on all assets
D. Invest only after major incidents

D3-Q482: Answer

Correct Answer: B

Optimizing ROI means protecting critical assets appropriately while avoiding overprotection of less critical ones.

D3-Q483: Compromised Admin Account

Question

Which control reduces impact of a compromised administrator account?

- A Multifactor authentication
- B Audit logging
- C Least privilege
- D Password policy

D3-Q483: Answer

Correct Answer: C

Least privilege limits the scope of damage even when credentials are compromised.

D3-Q484: Critical Element of Risk Program

Question

Which is critical for an effective risk management program?

- A Response strategy
- B Register content
- C Profile content
- D Risk owners and accountability

D3-Q484: Answer

Correct Answer: D

Risk owners are essential—they make informed, cost-effective decisions about controls for their owned risks.

D3-Q485: Anti-Malware Cost Exceeds Loss

Question

When anti-malware cost exceeds loss expectancy, the MOST viable response is:

A. Eliminate risk
B. Accept risk
C. Transfer risk
D. Mitigate risk

D3-Q485: Answer

Correct Answer: B

When response cost exceeds expected loss, risk acceptance is most economically viable.

D3-Q486: Risk Avoidance Behavior

Question

Which is the BEST example of risk avoidance?

- A Taking no action
- B Outsourcing the process
- C Insuring against an event
- D Exiting the activity that creates risk

D3-Q486: Answer

Correct Answer: D

Avoidance eliminates risk by exiting the activity—not by retaining, transferring, or mitigating it.

D3-Q487: Critical Dependencies in Treatment

Question

Which ensures critical dependencies are addressed in the risk treatment plan?

- A Treat all possible risk
- B Verify business objectives via top-down process review
- C Treat each risk independently
- D Verify objectives via bottom-up review

D3-Q487: Answer

Correct Answer: B

A top-down approach driven by business objectives ensures critical dependencies are addressed holistically.

D3-Q488: Controls to Mitigate Risk

Question

A CISO recommends anti-malware and similar controls. Which approach is being applied?

- A Transference
- B Mitigation
- C Acceptance
- D Avoidance

D3-Q488: Answer

Correct Answer: B

Implementing controls to reduce risk to acceptable levels is risk mitigation.

D3-Q489: Best Outsourcing Mitigation

Question

Which practice BEST mitigates outsourcing risk?

- A Audits to verify compliance
- B Vendor awareness training
- C Retaining copies of data
- D Reviewing vendor financials

D3-Q489: Answer

Correct Answer: A

Audits verify contract compliance and are the strongest mitigation for outsourcing risk.

D3-Q490: Best Risk Transfer

Question

Which risk is BEST addressed through transfer?

A. Old fire suppression system
B. Disgruntled employee sabotage
C. Disgruntled employee theft
D. Building in a 100-year flood plain

D3-Q490: Answer

Correct Answer: D

Flood insurance transfers the financial risk of a flood—a classic risk transfer scenario.

D3-Q491: Finalizing Risk Treatment Plan

Question

Which would BEST help finalize the risk treatment plan?

- A Vulnerability analysis
- B Impact analysis
- C Cost-benefit analysis
- D SWOT analysis

D3-Q491: Answer

Correct Answer: C

Cost-benefit analysis confirms that control benefits exceed costs, finalizing the treatment decision.

D3-Q492: Greatest Treatment Plan Benefit

Question

The GREATEST benefit of a risk treatment plan is to:

A. Reduce impact and likelihood of occurrence
B. Identify transferable risk
C. Exploit risk for preparedness
D. Enhance risk appetite

D3-Q492: Answer

Correct Answer: A

Treatment reduces the impact and likelihood of a risk event—its core purpose.

D3-Q493: Validating Patching Program

Question

What is the BEST method to validate the patching program?

- A Penetration testing
- B Risk identification
- C Vulnerability scanning
- D Request-for-change review

D3-Q493: Answer

Correct Answer: C

Vulnerability scans reveal whether patches have been installed on a timely basis.

D3-Q494: Most Important IS Control Design Factor

Question

What is the MOST important factor when designing IS controls in a complex environment?

A. Development methodology
B. Scalability
C. Platform interfaces
D. Stakeholder requirements

D3-Q494: Answer

Correct Answer: D

Controls must address stakeholder and business requirements to advance enterprise interests.

D3-Q495: EFT Testing Priority

Question

After major EFT enhancements, the risk practitioner would MOST benefit from a test that:

A. Identifies new gaps in security
B. Verifies recovery capability
C. Ensures performance to expectation
D. Ensures volume support

D3-Q495: Answer

Correct Answer: A

For a financial transfer system, security is the highest priority for risk practitioners; testing should reveal new security gaps.

D4-Q496: Log Management Concern

Question

Which is the PRIMARY purpose of log aggregation?

A. Identify and analyze important events
B. Synchronize clocks
C. Eliminate logging
D. Centralize storage only

D4-Q496: Answer

Correct Answer: A

Log aggregation helps identify and analyze important events and potential incidents across systems.

D4-Q497: SIEM Function

Question

SIEM systems primarily:

A. Correlate data from multiple sources
B. Store backup data
C. Manage user identities
D. Encrypt network traffic

D4-Q497: Answer

Correct Answer: A

SIEM tools capture and correlate events from multiple sources to detect security incidents.

D4-Q498: Log Review Challenge

Question

A common challenge with log review is:

A. Too much data to analyze effectively
B. Not enough data collected
C. Logs too expensive
D. Logs not required

D4-Q498: Answer

Correct Answer: A

Data volume, difficulty searching, misconfiguration, and pre-read modification are common log review challenges.

D4-Q499: Control Monitoring Purpose

Question

The purpose of control monitoring is to verify:

A. Whether the control is working
B. Whether the control is effectively addressing risk
C. Whether staff follows procedures
D. Whether logs are reviewed

D4-Q499: Answer

Correct Answer: B

Control monitoring verifies the control is effectively addressing risk—not merely that it operates.

D4-Q500: KRI Sensitivity

Question

A KRI that generates too many false positives should be adjusted for:

A. Sensitivity
B. Timeliness
C. Frequency
D. Reliability

D4-Q500: Answer

Correct Answer: A

Sensitivity thresholds control how often a KRI alerts; too many false positives indicates the threshold is too sensitive.

D4-Q501: KRI vs KPI

Question

Which statement BEST distinguishes KRIs from KPIs?

A. They measure the same thing

B. KPIs identify underperformance; KRIs provide early warnings

C. KRIs replace KPIs in mature organizations

D. They are unrelated

D4-Q501: Answer

Correct Answer: B

KPIs measure performance against objectives; KRIs provide early warnings of increasing risk. Both are complementary.

D4-Q502: KRI Evaluation Frequency

Question

KRIs should be evaluated:

A. Annually
B. Only when incidents occur
C. On a regular basis
D. Never after implementation

D4-Q502: Answer

Correct Answer: C

Because the internal and external environments change continuously, KRIs must be evaluated regularly to remain aligned with appetite.

D4-Q503: Control Effectiveness Verification

Question

One way to verify control effectiveness is by determining:

- A Its reliability
- B Whether it is preventive or detective
- C Capability of failure notification
- D Test results of intended objectives

D4-Q503: Answer

Correct Answer: D

Effectiveness is verified by testing whether the control achieves its intended objectives.

D4-Q504: KRI Reliability

Question

Which BEST describes KRI reliability?

A. It operates within thresholds
B. It tests the target at intervals
C. It flags exceptions every time they occur
D. It initiates corrective action

D4-Q504: Answer

Correct Answer: C

A reliable KRI consistently flags exceptions when they occur, indicating a strong correlation with the risk.

D4-Q505: SIEM for Incident Source

Question

Which system BEST provides information for investigating the root cause of a security incident?

A. IDS
B. IPS
C. Configuration management
D. Event management (SIEM)

D4-Q505: Answer

Correct Answer: D

SIEM merges logs from multiple systems, enabling full data set analysis for root cause investigation.

D4-Q506: Best Control for Unauthorized Access

Question

The BEST control to prevent unauthorized access is user:

A. Accountability
B. Authentication
C. Identification
D. Access rules

D4-Q506: Answer

Correct Answer: B

Authentication verifies user identity before granting access—preventing unauthorized users.

D4-Q507: Need-to-Know Access

Question

The BEST control for protecting sensitive information from unauthorized access is:

A. Challenge-response system
B. Periodic password changes
C. Monitoring failed logins
D. Need-to-know access

D4-Q507: Answer

Correct Answer: D

Need-to-know access embodies least privilege and segregation of duties—fundamental controls.

D4-Q508: Best Defense Against Phishing

Question

The BEST defense against phishing attacks is:

A. IDS
B. Spam filters
C. End-user awareness
D. Application hardening

D4-Q508: Answer

Correct Answer: C

Phishing is a social engineering attack; user awareness training is the best defense.

D4-Q509: Hashing Purpose

Question

The primary purpose of hashing is to:

A. Provide confidentiality
B. Verify data integrity
C. Provide authorization
D. Facilitate key exchange

D4-Q509: Answer

Correct Answer: B

Hashing generates a fixed-length value used to verify that data has not been altered.

D4-Q510: Digital Signature Provides

Question

Which does NOT come from a digital signature?

- A Integrity
- B Nonrepudiation
- C Authenticity
- D Confidentiality

D4-Q510: Answer

Correct Answer: D

Digital signatures provide integrity, nonrepudiation, and authenticity—not confidentiality.

D4-Q511: Encrypt for Receiver Only

Question

To ensure only the receiver can decrypt, the sender uses:

A. Receiver's public key
B. Sender's public key
C. Receiver's private key
D. Sender's private key

D4-Q511: Answer

Correct Answer: A

Encrypting with the receiver's public key ensures only the receiver can decrypt with their private key.

D4-Q512: Signed and Encrypted Provides

Question

Which cryptographic mechanism provides confidentiality, integrity, and nonrepudiation?

- A Signed only
- B Encrypted only
- C Signed and encrypted
- D Signed and hashed

D4-Q512: Answer

Correct Answer: C

Encryption provides confidentiality; digital signature provides integrity and nonrepudiation. Together they cover all three.

D4-Q513: PKI Single Point of Failure

Question

Which is a single point of failure in a PKI ecosystem?

A. Certificate
B. Certificate Authority (CA)
C. Requester
D. Browser

D4-Q513: Answer

Correct Answer: B

If the CA's private key is compromised, confidence in all certificates it issued collapses.

D4-Q514: Security Awareness Primary Goal

Question

The most important goal of security awareness training is:

A. Train on latest threats
B. Demonstrate audit compliance
C. Create a security-conscious culture
D. Upskill employees

D4-Q514: Answer

Correct Answer: C

Creating a security-conscious culture is the primary, lasting goal of awareness training.

D4-Q515: Data Security vs Privacy

Question

Which statement about data security and data privacy is TRUE?

A. They are identical

B. Security protects data; privacy governs its proper use

C. Privacy is more important than security

D. Security applies only to personal data

D4-Q515: Answer

Correct Answer: B

Security protects data from unauthorized access; privacy governs appropriate use of personal information. Strong security does not guarantee privacy.

D1-Q316: Risk and Control Ownership

Question

Which of the following is MOST important when assigning risk and control ownership in an enterprise?

A. The number of controls each owner manages
B. Clear definition of roles and accountability
C. The technical expertise of each owner
D. The organizational level of each owner

D1-Q316: Answer

Correct Answer: B

Clear definition of roles and accountability is the most important factor. Without unambiguous ownership, controls may be duplicated, neglected, or contested, and accountability for risk cannot be enforced.

D1-Q317: Board Oversight of IT Risk

Question

Which mechanism BEST enables a board of directors to oversee IT risk effectively?

A. Receiving detailed technical vulnerability reports
B. Periodic reporting of aggregated risk against appetite
C. Delegating all IT risk decisions to the CIO
D. Reviewing individual firewall configurations

D1-Q317: Answer

Correct Answer: B

Boards need aggregated risk information aligned to risk appetite and tolerance, not technical detail. This allows them to provide direction and oversight without micromanaging operations.

D1-Q318: Risk Governance Principles

Question

Which principle is MOST fundamental to effective risk governance?

A. Risk is managed primarily by the internal audit function
B. Risk decisions are made at the lowest possible cost
C. Risk oversight is independent from risk-taking activities
D. All risk must be eliminated before business proceeds

D1-Q318: Answer

Correct Answer: C

Independence of oversight from risk-taking activities ensures objectivity. This is the foundation of the three lines of defense model and prevents conflicts of interest.

D1-Q319: Enterprise Risk Culture Indicators

Question

Which is the BEST indicator of a healthy enterprise risk culture?

A. Few risks are reported because issues are resolved quietly
B. Employees escalate concerns without fear of retaliation
C. Risk assessments are performed only when required
D. Senior management rarely discusses risk

D1-Q319: Answer

Correct Answer: B

A healthy risk culture encourages open escalation and psychological safety. Fear of retaliation is a hallmark of a blame culture that suppresses risk reporting.

D1-Q320: Risk Appetite Statement Content

Question

Which element is MOST essential in a risk appetite statement?

A. A list of all identified risks
B. The amount and type of risk the enterprise is willing to accept
C. Detailed control procedures for each business unit
D. The names of all risk owners

D1-Q320: Answer

Correct Answer: B

A risk appetite statement articulates the amount and type of risk the enterprise is willing to accept in pursuit of its objectives. It guides decision-making at all levels.

D1-Q321: Risk Culture and Incentives

Question

How do incentive structures MOST influence enterprise risk culture?

A. They have no effect on how employees treat risk
B. They align employee behavior with desired risk-taking boundaries
C. They eliminate the need for formal risk policies
D. They guarantee that no risk events will occur

D1-Q321: Answer

Correct Answer: B

Incentives that reward appropriate risk-taking and penalize reckless behavior align employee actions with the enterprise's risk appetite. Misaligned incentives can undermine even well-designed controls.

D1-Q322: Risk Governance Maturity

Question

Which characteristic BEST indicates a mature risk governance structure?

- A Risk is managed reactively after incidents occur
- B Risk considerations are integrated into strategic planning
- C Risk management is performed only by the risk department
- D Risk reports are produced annually for compliance

D1-Q322: Answer

Correct Answer: B

Mature governance integrates risk into strategy, budgeting, and operations. Reactive or siloed risk management indicates lower maturity.

D1-Q323: Communicating Risk Appetite

Question

What is the BEST way to ensure risk appetite is understood throughout the enterprise?

A. Publish the appetite statement only on the intranet

B. Translate appetite into specific tolerances and metrics for each business unit

C. Discuss appetite only at board meetings

D. Include appetite in the annual audit report

D1-Q323: Answer

Correct Answer: B

Translating high-level appetite into concrete tolerances, thresholds, and metrics makes it actionable for each business unit. A statement alone is insufficient.

D1-Q324: Risk Governance Failures

Question

Which is the MOST common root cause of risk governance failures?

A. Insufficient technical tools
B. Lack of clear accountability and oversight
C. Too many risk assessments
D. Excessive regulatory requirements

D1-Q324: Answer

Correct Answer: B

Governance failures most often stem from unclear accountability, inadequate oversight, and poorly defined roles—not from tooling or assessment frequency.

D1-Q325: Board Risk Committee

Question

What is the PRIMARY role of a board-level risk committee?

- A Execute day-to-day risk management activities
- B Oversee the enterprise risk management framework and risk appetite
- C Conduct detailed technical risk assessments
- D Approve individual risk treatment plans

D1-Q325: Answer

Correct Answer: B

A board risk committee provides oversight of the ERM framework, risk appetite, and key risk exposures. Execution and technical assessment are delegated to management.

D1-Q326: Risk Reporting to the Board

Question

Which characteristic makes risk reporting MOST useful to the board?

- (A) Inclusion of every identified risk in detail
- (B) Focus on aggregated exposures against appetite with clear trends
- (C) Use of technical jargon to demonstrate expertise
- (D) Frequency of at least weekly

D1-Q326: Answer

Correct Answer: B

Boards need aggregated, trend-oriented views against appetite—not exhaustive detail. This enables strategic oversight and informed decision-making.

D1-Q327: Risk Ownership Delegation

Question

Which statement about risk ownership delegation is TRUE?

A. Accountability can be delegated along with responsibility

B. Responsibility can be delegated, but accountability cannot

C. Neither responsibility nor accountability can be delegated

D. Both responsibility and accountability are optional

D1-Q327: Answer

Correct Answer: B

Responsibility for tasks can be delegated, but accountability for outcomes remains with the original owner. This is a core governance principle.

D1-Q328: Risk Governance in M&A

Question

What is the FIRST risk governance consideration during a merger or acquisition?

A. Harmonizing technical platforms
B. Assessing the target's risk culture and governance maturity
C. Reducing headcount
D. Standardizing job titles

D1-Q328: Answer

Correct Answer: B

Understanding the target's risk culture and governance maturity is foundational. Cultural and governance misalignment is a leading cause of failed integrations.

D1-Q329: Regulatory Expectation for Governance

Question

What do regulators MOST commonly expect regarding enterprise risk governance?

A. That all risk is eliminated
B. That a documented, enforced governance framework exists
C. That risk is managed only by external consultants
D. That risk reporting is optional

D1-Q329: Answer

Correct Answer: B

Regulators expect documented governance frameworks with clear roles, accountability, and evidence of enforcement—not risk elimination.

D1-Q330: Risk Culture and Whistleblowing

Question

Which mechanism BEST supports a healthy risk culture?

- A Anonymous whistleblowing channels with non-retaliation policies
- B Strict punishment for all reported issues
- C Discouraging escalation to avoid panic
- D Restricting risk discussions to executives only

D1-Q330: Answer

Correct Answer: A

Anonymous reporting channels with strong non-retaliation protections encourage early disclosure and reduce the risk of hidden issues escalating.

D1-Q331: Governance of Third Parties

Question

Which is MOST important for governing third-party risk at the enterprise level?

A. Delegating all oversight to the vendor

B. A centralized third-party risk management program with clear accountability

C. Reviewing vendor contracts annually only

D. Relying on vendor self-assessments alone

D1-Q331: Answer

Correct Answer: B

A centralized program with clear accountability ensures consistent due diligence, contracting, monitoring, and termination practices across all third parties.

D1-Q332: Risk Governance and Business Strategy

Question

How should risk governance relate to business strategy?

- (A) Risk governance should be independent and unrelated to strategy
- (B) Risk governance should enable strategy by identifying and managing risk to objectives
- (C) Risk governance should prevent any strategic change
- (D) Risk governance should replace strategic planning

D1-Q332: Answer

Correct Answer: B

Effective risk governance enables strategy by ensuring risks to objectives are identified, assessed, and managed within appetite—not by blocking change.

D1-Q333: Risk Governance and Performance

Question

Which is the BEST measure of risk governance effectiveness?

A. The number of risk policies published
B. The degree to which risk-informed decisions are made and evidenced
C. The size of the risk management department
D. The frequency of risk committee meetings

D1-Q333: Answer

Correct Answer: B

Effectiveness is measured by whether risk information actually informs decisions—not by documentation volume, headcount, or meeting frequency.

D1-Q334: Governance and Risk Aggregation

Question

Why is risk aggregation important for enterprise governance?

A. It eliminates the need for business-unit risk registers

B. It provides a holistic view of exposures that may exceed appetite

C. It ensures every risk has a unique owner

D. It replaces the need for risk assessment

D1-Q334: Answer

Correct Answer: B

Aggregation reveals concentrations and cumulative exposures that may individually appear acceptable but collectively exceed appetite—critical for board oversight.

D1-Q335: Risk Governance in Acquisitions

Question

During due diligence, which governance artifact is MOST valuable to review?

- A The target's marketing materials
- B The target's risk register, appetite statement, and governance charters
- C The target's employee newsletter
- D The target's social media presence

D1-Q335: Answer

Correct Answer: B

Risk registers, appetite statements, and governance charters reveal the target's risk maturity, exposures, and accountability structures—essential for integration planning.

D1-Q336: Governance and Risk Appetite Revision

Question

Who should approve changes to the enterprise risk appetite?

A. The risk management department
B. The board of directors with senior management input
C. Individual business unit managers
D. The internal audit function

D1-Q336: Answer

Correct Answer: B

Risk appetite is a board-level decision informed by senior management. It reflects the enterprise's strategic direction and tolerance for risk.

D1-Q337: Risk Governance and Regulation

Question

Which is the BEST way to integrate regulatory requirements into risk governance?

A. Treat compliance as a separate function from risk management

B. Map regulatory obligations to risk categories and controls within the ERM framework

C. Wait for regulators to identify gaps

D. Delegate compliance entirely to external counsel

D1-Q337: Answer

Correct Answer: B

Mapping obligations to risk categories and controls ensures compliance is managed proactively within the ERM framework rather than as an isolated activity.

D1-Q338: Governance and Risk Tolerance

Question

Which statement about risk tolerance is TRUE?

A. Tolerance is the same for every risk category

B. Tolerance translates appetite into measurable limits for specific risks

C. Tolerance is set by the internal audit function

D. Tolerance is optional if appetite is documented

D1-Q338: Answer

Correct Answer: B

Tolerance operationalizes appetite by setting specific, measurable limits for individual risk categories, enabling monitoring and escalation.

D1-Q339: Governance and Culture Metrics

Question

Which metric BEST reflects the health of an enterprise's risk culture?

- A Number of risk policies published
- B Percentage of employees who report they feel safe raising risk concerns
- C Number of risk committee meetings held
- D Total spend on risk management tools

D1-Q339: Answer

Correct Answer: B

Psychological safety—measured through employee surveys—is a leading indicator of a healthy risk culture where issues are surfaced early.

D1-Q340: Governance and Emerging Risk

Question

How should emerging risk be governed at the enterprise level?

- (A) Ignore emerging risk until it becomes a realized loss
- (B) Establish a process for identifying, assessing, and escalating emerging risk
- (C) Delegate emerging risk entirely to IT
- (D) Report emerging risk only to external auditors

D1-Q340: Answer

Correct Answer: B

A structured process for identifying, assessing, and escalating emerging risk enables proactive management before issues crystallize into material losses.

D2-Q341: Risk Assessment Scope

Question

What is the FIRST step in defining the scope of a risk assessment?

- A Identify all possible threats
- B Define the business objectives and processes in scope
- C Select the risk assessment tool
- D Assign risk owners

D2-Q341: Answer

Correct Answer: B

Scope is defined by the business objectives and processes under consideration. Threats, tools, and owners follow from a clear scope.

D2-Q342: Asset Valuation Methods

Question

Which method is MOST appropriate for valuing an asset used in risk analysis?

A. Original purchase price only
B. Replacement cost combined with business criticality
C. Depreciation book value
D. Insurance deductible amount

D2-Q342: Answer

Correct Answer: B

Asset value in risk analysis must reflect both replacement cost and the business impact of loss, including criticality to operations.

D2-Q343: Threat Modeling Purpose

Question

What is the PRIMARY purpose of threat modeling in risk assessment?

A. To document all possible attack vectors

B. To understand how threats could exploit vulnerabilities to achieve objectives

C. To replace the need for vulnerability scanning

D. To assign blame for past incidents

D2-Q343: Answer

Correct Answer: B

Threat modeling systematically examines how potential threats could exploit weaknesses to achieve adversarial or accidental objectives, informing risk prioritization.

D2-Q344: Qualitative Risk Scoring

Question

Which is a limitation of qualitative risk scoring?

- A It is always more expensive than quantitative analysis
- B Scores can be subjective and inconsistent across assessors
- C It requires specialized statistical expertise
- D It cannot be used for prioritization

D2-Q344: Answer

Correct Answer: B

Qualitative scoring depends on expert judgment and can vary between assessors. Calibration and clear criteria help mitigate subjectivity.

D2-Q345: Risk Scenario Development

Question

Which is the BEST source of input for developing risk scenarios?

A. Vendor marketing materials
B. Historical incidents, threat intelligence, and business objectives
C. Social media trends
D. Only internal audit findings

D2-Q345: Answer

Correct Answer: B

Effective risk scenarios draw on historical incidents, current threat intelligence, and business objectives to ensure relevance and realism.

D2-Q346: Risk Heat Map

Question

What is the PRIMARY purpose of a risk heat map?

A. To calculate exact loss amounts

B. To visualize and communicate risk based on likelihood and impact

C. To replace the risk register

D. To document control procedures

D2-Q346: Answer

Correct Answer: B

A heat map displays risks by likelihood and impact, enabling quick visual comparison and prioritization for stakeholders.

D2-Q347: Risk Register Updates

Question

When should the risk register be updated?

A. Only during the annual risk assessment

B. Continuously as new information becomes available

C. Only when incidents occur

D. Only when regulators request it

D2-Q347: Answer

Correct Answer: B

The risk register should be a living document updated as new risks emerge, controls change, or risk levels shift—not only on an annual cycle.

D2-Q348: Inherent Risk Assessment

Question

What does inherent risk assessment measure?

- A Risk after all controls are implemented
- B Risk before considering any controls
- C Risk related only to financial loss
- D Risk accepted by management

D2-Q348: Answer

Correct Answer: B

Inherent risk is the level of risk present before any controls are considered, providing a baseline for evaluating control effectiveness.

D2-Q349: Residual Risk Monitoring

Question

Why must residual risk be monitored continuously?

A. Because controls degrade or become outdated over time

B. Because inherent risk always decreases

C. Because threats never change

D. Because regulatory requirements are static

D2-Q349: Answer

Correct Answer: A

Controls can degrade, become misconfigured, or be bypassed, and threats and business conditions evolve—so residual risk must be continually reassessed.

D2-Q350: Risk Tolerance and Assessment

Question

How does risk tolerance affect the risk assessment process?

A. It determines which risks require treatment and escalation

B. It eliminates the need for risk assessment

C. It makes all risks acceptable

D. It replaces the risk register

D2-Q350: Answer

Correct Answer: A

Risk tolerance defines thresholds above which risks must be treated or escalated, guiding prioritization and response within the assessment process.

D2-Q351: Risk Assessment Frequency

Question

What is the BEST approach for determining how often risk assessments should be performed?

A. Always annually regardless of changes

B. Based on the rate of change in the risk environment and criticality of assets

C. Only when mandated by regulation

D. Never, once the initial assessment is complete

D2-Q351: Answer

Correct Answer: B

Assessment frequency should reflect the pace of change in threats, vulnerabilities, and business conditions, and the criticality of assets assessed.

D2-Q352: Risk Appetite and Risk Assessment

Question

How does risk appetite inform risk assessment results?

- A. It determines which risks are within acceptable bounds and which require action
- B. It eliminates the need for risk scoring
- C. It applies only to financial risks
- D. It prevents any risk from being identified

D2-Q352: Answer

Correct Answer: A

Risk appetite provides the reference point against which assessed risk levels are compared to determine acceptability and the need for treatment.

D2-Q353: Monte Carlo Simulation

Question

When is Monte Carlo simulation MOST useful in risk assessment?

A. When a single deterministic outcome is needed

B. When modeling the range of possible outcomes from multiple uncertain inputs

C. When qualitative judgment alone is sufficient

D. When only one variable affects the outcome

D2-Q353: Answer

Correct Answer: B

Monte Carlo simulation models the distribution of possible outcomes given multiple uncertain inputs, providing a probabilistic view of risk exposure.

D2-Q354: Risk Register Completeness

Question

Which is the MOST important criterion for a complete risk register?

A. Every conceivable risk, no matter how trivial, is listed

B. All material risks to business objectives are identified and assessed

C. Only technical risks are documented

D. Only risks with known solutions are included

D2-Q354: Answer

Correct Answer: B

A complete register captures material risks to business objectives. Including every trivial risk dilutes focus; excluding material risks leaves exposure unmanaged.

D2-Q355: Risk Assessment Stakeholders

Question

Who should be involved in a risk assessment to ensure it is comprehensive?

- A Only the IT security team
- B Business process owners, IT, risk management, and compliance
- C Only external auditors
- D Only senior executives

D2-Q355: Answer

Correct Answer: B

Comprehensive risk assessment requires cross-functional input to capture business, technical, regulatory, and operational perspectives.

D2-Q356: Risk Assessment Reporting

Question

Which is the MOST important element of a risk assessment report to management?

A. Detailed technical vulnerability listings

B. Clear linkage between risks, business impact, and recommended actions

C. Exhaustive threat catalogs

D. Methodological appendices

D2-Q356: Answer

Correct Answer: B

Management needs to understand how risks affect business objectives and what actions are recommended—technical detail supports but does not replace this.

D2-Q357: Risk Assessment and Control Testing

Question

How does control testing relate to risk assessment?

A. Control testing replaces risk assessment

B. Control testing provides evidence that controls are reducing risk as expected

C. Control testing is unrelated to risk

D. Control testing only applies to financial controls

D2-Q357: Answer

Correct Answer: B

Control testing verifies that controls operate effectively, validating the residual risk estimates produced by the risk assessment.

D2-Q358: Risk Assessment for Cloud

Question

Which additional consideration is MOST important in a cloud risk assessment?

- A Physical security of the provider's data center
- B Shared responsibility model and provider assurance
- C The provider's marketing claims
- D The provider's stock price

D2-Q358: Answer

Correct Answer: B

Cloud risk assessment must clarify which controls the provider owns versus the customer under the shared responsibility model, supported by independent assurance.

D2-Q359: Risk Assessment and Business Impact

Question

How should business impact analysis (BIA) and risk assessment be integrated?

A. BIA replaces risk assessment

B. BIA provides business impact data that informs risk prioritization and treatment

C. They should never be linked

D. Risk assessment provides recovery time objectives

D2-Q359: Answer

Correct Answer: B

BIA quantifies business impact of disruptions, which risk assessment uses to prioritize risks and justify treatment decisions.

D2-Q360: Risk Assessment and Regulatory Requirements

Question

How should regulatory requirements be treated in a risk assessment?

A. Ignored because they are not business risks
B. Assessed as sources of risk and compliance obligations
C. Assumed to be satisfied by existing controls
D. Delegated entirely to legal counsel

D2-Q360: Answer

Correct Answer: B

Regulatory obligations create risk of noncompliance and should be assessed alongside other risks, with controls evaluated for adequacy.

D2-Q361: Risk Assessment Scenario

Question

Which is the BEST example of a well-formed risk scenario?

A. "The system might fail"

B. "A phishing attack could compromise credentials, leading to unauthorized access to customer data and regulatory penalties"

C. "Hackers are bad"

D. "We need better security"

D2-Q361: Answer

Correct Answer: B

A well-formed scenario describes cause, event, and business consequence, enabling meaningful likelihood and impact assessment.

D2-Q362: Risk Appetite and Risk Assessment Results

Question

What should happen when risk assessment results exceed risk appetite?

A. Ignore the results

B. Escalate to risk owners and determine treatment options

C. Revise the assessment methodology

D. Accept the risk without documentation

D2-Q362: Answer

Correct Answer: B

When risk exceeds appetite, it must be escalated to risk owners for treatment decisions—acceptance requires documented approval and compensating controls.

D2-Q363: Risk Assessment and Key Risk Indicators

Question

How do KRIs relate to risk assessment?

A. KRIs replace the need for periodic risk assessment

B. KRIs provide early warning that a risk assessment update may be needed

C. KRIs are only used after incidents

D. KRIs are unrelated to risk assessment

D2-Q363: Answer

Correct Answer: B

KRIs monitor changes in risk exposure over time. Breaching a KRI threshold signals that the risk assessment should be revisited.

D2-Q364: Risk Assessment and Emerging Risk

Question

How should emerging risk be handled in the risk assessment process?

A. Wait until it becomes a realized risk
B. Include a horizon-scanning process to identify and assess emerging risk
C. Exclude emerging risk from the register
D. Delegate entirely to IT

D2-Q364: Answer

Correct Answer: B

Horizon scanning identifies emerging risks early, allowing proactive assessment and treatment before they materialize.

D2-Q365: Risk Assessment and Business Objectives

Question

Why must risk assessment be tied to business objectives?

- A To make assessments longer
- B To ensure risk evaluation reflects what the business is trying to achieve
- C To satisfy auditors only
- D To avoid identifying technical risks

D2-Q365: Answer

Correct Answer: B

Risk has meaning only in relation to objectives. Aligning assessment with business objectives ensures relevance and enables risk-informed decision-making.

D3-Q366: Risk Treatment Plan Components

Question

Which is the MOST important component of a risk treatment plan?

A. The name of the auditor who approved it
B. Specific actions, owners, and target dates for reducing risk
C. The total budget allocated
D. The tool used to document it

D3-Q366: Answer

Correct Answer: B

A treatment plan must specify actions, accountable owners, and target dates. Without these elements, the plan cannot be executed or monitored.

D3-Q367: Risk Response and Residual Risk

Question

What is the PRIMARY goal of selecting a risk response?

- A Eliminate all residual risk
- B Reduce residual risk to within risk tolerance
- C Increase inherent risk
- D Avoid documenting the response

D3-Q367: Answer

Correct Answer: B

The goal is to reduce residual risk to acceptable levels within appetite and tolerance—not to eliminate all risk, which is usually impossible.

D3-Q368: Risk Response and Cost-Benefit

Question

When should a risk response NOT be implemented?

A. When it reduces risk below tolerance
B. When the cost exceeds the benefit of risk reduction
C. When it is required by regulation
D. When management approves it

D3-Q368: Answer

Correct Answer: B

If the cost of a control exceeds its benefit, the response is not economically justified. Regulatory requirements may override cost-benefit considerations.

D3-Q369: Risk Transfer Limitations

Question

Which is a limitation of risk transfer?

- A It eliminates all risk
- B It does not eliminate reputational or legal risk
- C It is always more expensive than mitigation
- D It is prohibited by regulators

D3-Q369: Answer

Correct Answer: B

Risk transfer (e.g., insurance) shifts financial impact but not reputational, legal, or operational consequences. The enterprise remains exposed to those.

D3-Q370: Risk Acceptance Criteria

Question

Which is the BEST criterion for accepting a risk?

- A. The risk is within the enterprise's risk appetite and tolerance
- B. The risk has never occurred before
- C. No one has complained about the risk
- D. Insurance is too expensive

D3-Q370: Answer

Correct Answer: A

Risk acceptance is appropriate when the risk falls within the enterprise's appetite and tolerance. Acceptance must be documented and approved by the risk owner.

D3-Q371: Risk Avoidance Consequences

Question

What is a common consequence of risk avoidance?

- A Loss of business opportunity
- B Increased residual risk
- C Decreased compliance
- D Elimination of inherent risk only

D3-Q371: Answer

Correct Answer: A

Avoidance eliminates risk by exiting the activity but often forfeits associated opportunities, making it unsuitable when the business value is high.

D3-Q372: Risk Mitigation Cost

Question

What is the BEST way to justify the cost of a risk mitigation control?

A. Compare the cost with the expected reduction in risk exposure
B. Present the cost alone
C. Compare the cost with the enterprise's total IT budget
D. Avoid discussing cost

D3-Q372: Answer

Correct Answer: A

Justification requires demonstrating that the control reduces risk by an amount whose value exceeds the control's total cost of ownership.

D3-Q373: Control Ownership

Question

What is the PRIMARY responsibility of a control owner?

- A Approve the enterprise risk appetite
- B Ensure the control operates effectively and is monitored
- C Conduct independent audits
- D Set the risk tolerance

D3-Q373: Answer

Correct Answer: B

Control owners are accountable for ensuring controls operate as designed, are monitored, and are updated as conditions change.

D3-Q374 Risk Response for Regulatory Risk

Question

Which response is MOST appropriate for a regulatory compliance risk?

- (A) Accept the risk and hope for no enforcement
- (B) Mitigate by implementing required controls and monitoring compliance
- (C) Transfer the risk through insurance only
- (D) Ignore the risk until inspected

D3-Q374 Answer

Correct Answer: B

Regulatory risk is typically mitigated through required controls and compliance monitoring. Acceptance is rarely justified given enforcement and reputational consequences.

D3-Q375: Risk Response and Stakeholder Engagement

Question

Which stakeholders are MOST important to engage when selecting a risk response?

A. Only the IT department
B. Business owners, risk owners, and affected operational teams
C. Only external auditors
D. Only the legal department

D3-Q375: Answer

Correct Answer: B

Those who own the risk and are affected by the response must be engaged to ensure the response is feasible, acceptable, and sustainable.

D3-Q376: Risk Response Monitoring

Question

How should the effectiveness of a risk response be monitored?

A. Only through annual audits

B. Through KPIs, KCIs, and periodic reviews of residual risk

C. By asking the vendor

D. By reviewing social media

D3-Q376: Answer

Correct Answer: B

Monitoring should combine performance indicators, control indicators, and periodic reassessment of residual risk against appetite.

D3-Q377: Risk Response Documentation

Question

Why must risk responses be documented?

A. To increase paperwork

B. To provide evidence of decisions, accountability, and monitoring

C. To satisfy vendor requirements

D. To avoid escalation

D3-Q377: Answer

Correct Answer: B

Documentation provides evidence that responses were chosen deliberately, owners assigned, and results monitored—essential for accountability and audit.

D3-Q378: Risk Response and Residual Risk Acceptance

Question

Who should formally accept residual risk after treatment?

A. The control owner

B. The risk owner with appropriate management approval

C. The internal auditor

D. The IT administrator

D3-Q378: Answer

Correct Answer: B

Residual risk acceptance rests with the risk owner, with approval from management at the appropriate level based on the risk's significance.

D3-Q379: Risk Response and Insurance

Question

Which type of risk is MOST suitable for transfer through insurance?

A. High-likelihood, low-impact operational errors
B. Low-likelihood, high-impact catastrophic events
C. Risks that are entirely within the organization's control
D. Risks with no measurable financial consequence

D3-Q379: Answer

Correct Answer: B

Insurance is most economically efficient for low-frequency, high-severity events that would otherwise threaten the enterprise's financial stability.

D3-Q380: Risk Reporting Frequency

Question

What is the BEST approach for determining risk reporting frequency to senior management?

A. Always monthly
B. Aligned with the pace of change and criticality of the risks reported
C. Only annually
D. Only after incidents

D3-Q380: Answer

Correct Answer: B

Reporting frequency should reflect how rapidly the risk environment changes and how critical those risks are to business objectives.

D3-Q381: Risk Reporting Content

Question

Which content is MOST valuable in a risk report to senior management?

A. Raw vulnerability scan output

B. Aggregated risk against appetite, key changes, and recommended actions

C. Exhaustive threat intelligence feeds

D. Detailed configuration settings

D3-Q381: Answer

Correct Answer: B

Executive reporting should focus on aggregated risk, changes since the last report, and recommended actions—not technical detail.

D3-Q382: Risk Response and Regulations

Question

How should regulatory requirements influence risk response selection?

A. They can be ignored if mitigation is expensive
B. They may mandate specific responses regardless of cost-benefit
C. They are only relevant to financial institutions
D. They should be delegated to external counsel

D3-Q382: Answer

Correct Answer: B

Regulatory requirements may compel specific controls or responses irrespective of cost-benefit analysis. Noncompliance carries penalties and reputational harm.

D3-Q383: Risk Response and Third Parties

Question

Which is MOST important when relying on a third party for risk mitigation?

A. The third party's marketing claims
B. Contractual requirements, audit rights, and monitoring
C. The third party's size
D. The third party's location

D3-Q383: Answer

Correct Answer: B

Contractual requirements, audit rights, and ongoing monitoring ensure the third party actually delivers the risk reduction expected.

D3-Q384: Risk Response and Residual Risk Target

Question

What should be the target level of residual risk after treatment?

A. Zero
B. Within the enterprise's risk appetite and tolerance
C. As high as possible
D. Undefined

D3-Q384: Answer

Correct Answer: B

The target is to bring residual risk within appetite and tolerance. Zero risk is generally neither achievable nor economically justified.

D3-Q385: Risk Response and Change Management

Question

How does change management relate to risk response?

A. Change management is unrelated to risk

B. Changes can introduce new risks and must be assessed before implementation

C. Change management replaces risk response

D. All changes are risk-free if approved

D3-Q385: Answer

Correct Answer: B

Changes to systems, processes, or controls can introduce new risks or alter existing ones, so they must be assessed through change management.

D3-Q386: Risk Response and Emerging Risk

Question

How should risk responses address emerging risk?

- A Ignore emerging risk until it materializes
- B Monitor emerging risk and prepare contingency responses
- C Treat emerging risk the same as known risk without assessment
- D Delegate to the vendor

D3-Q386: Answer

Correct Answer: B

Emerging risk should be monitored through horizon scanning, with contingency responses prepared for plausible scenarios.

D3-Q387: Risk Response and Business Continuity

Question

How does business continuity planning relate to risk response?

A. It replaces risk response
B. It provides a response for risks that cannot be fully mitigated
C. It is unrelated to risk response
D. It is only for natural disasters

D3-Q387: Answer

Correct Answer: B

Business continuity provides response and recovery capabilities for risks that cannot be fully mitigated, ensuring resilience.

D3-Q388: Risk Response and Control Design

Question

What is the FIRST consideration when designing a control as a risk response?

A. Cost of the control
B. The specific risk and its root cause the control is meant to address
C. The vendor's reputation
D. The control's popularity in the industry

D3-Q388: Answer

Correct Answer: B

Controls must be designed to address the specific risk and its root cause. Otherwise, the control may be ineffective regardless of cost or popularity.

D3-Q389: Risk Response and Monitoring Metrics

Question

Which metric BEST indicates a risk response is effective?

A. Number of controls implemented
B. Reduction in residual risk relative to tolerance
C. Amount spent on controls
D. Frequency of control audits

D3-Q389: Answer

Correct Answer: B

Effectiveness is measured by the reduction in residual risk achieved relative to tolerance—not by activity metrics.

D3-Q390: Risk Response and Residual Risk Escalation

Question

When should residual risk be escalated?

- A. Never
- B. When it exceeds tolerance or appetite
- C. Only after an incident
- D. Only if the auditor requests it

D3-Q390: Answer

Correct Answer: B

Residual risk exceeding tolerance or appetite must be escalated to appropriate management for decision on further treatment or acceptance.

D3-Q391: Risk Response and Accountability

Question

Who is accountable for the effectiveness of a risk response?

- A The control vendor
- B The risk owner
- C The internal auditor
- D The IT administrator

D3-Q391: Answer

Correct Answer: B

The risk owner is accountable for ensuring the chosen response is implemented, monitored, and effective.

D3-Q392: Risk Response and Documentation

Question

Which element is MOST important to document for a risk response?

- A The response rationale, owner, and target date
- B The vendor's contact information
- C The control's technical specification
- D The marketing brochure

D3-Q392: Answer

Correct Answer: A

Documenting the rationale, owner, and target date provides accountability and enables monitoring. Technical details may be additional but are not primary.

D3-Q393: Risk Response and Regulatory Reporting

Question

How should regulatory reporting requirements affect risk response documentation?

A. They have no impact
B. They may dictate specific documentation and reporting obligations
C. They only apply to financial firms
D. They can be ignored

D3-Q393: Answer

Correct Answer: B

Regulatory requirements may impose specific documentation, retention, and reporting obligations that must be reflected in risk response processes.

D3-Q394: Risk Response and Residual Risk Reporting

Question

Which is MOST valuable in reporting residual risk to management?

- (A) A comparison of residual risk against appetite and tolerance with trends
- (B) Raw control inventory
- (C) The number of policies published
- (D) Vendor performance metrics

D3-Q394: Answer

Correct Answer: A

Management needs to see residual risk relative to appetite and tolerance, with trends over time, to make informed decisions.

D3-Q395: Risk Response and Continuous Improvement

Question

How should lessons learned from risk responses be used?

- A. Filed and forgotten
- B. To improve future risk assessments and response selection
- C. To assign blame
- D. Shared only with auditors

D3-Q395: Answer

Correct Answer: B

Lessons learned should feed back into the risk management process to improve future assessments, response selection, and control design.

D4-Q396: Security Architecture Purpose

Question

What is the PRIMARY purpose of an enterprise security architecture?

- A To replace the risk register
- B To align security controls and strategies with business objectives
- C To document every vulnerability
- D To eliminate the need for security policies

D4-Q396: Answer

Correct Answer: B

Enterprise security architecture aligns security strategies and controls with business objectives, ensuring coherent and integrated protection.

D4-Q397: Access Control Models

Question

Which access control model is MOST appropriate for an enterprise with highly dynamic roles?

A. Mandatory access control (MAC)
B. Role-based access control (RBAC)
C. Discretionary access control (DAC)
D. Rule-based access control without roles

D4-Q397: Answer

Correct Answer: B

RBAC maps access to roles rather than individuals, simplifying administration and accommodating dynamic role assignments.

D4-Q398: Encryption Key Management

Question

Which is the MOST critical aspect of encryption key management?

- A Publishing keys for transparency
- B Secure generation, distribution, storage, and rotation of keys
- C Using the same key indefinitely
- D Storing keys with the encrypted data

D4-Q398: Answer

Correct Answer: B

Key management must ensure secure generation, distribution, storage, rotation, and destruction of keys—otherwise encryption provides no protection.

D4-Q399: Security Awareness Training

Question

What is the MOST effective format for ongoing security awareness training?

- A Annual classroom training only
- B Continuous, role-specific, and reinforced through simulations
- C A single email at hire
- D A poster in the break room

D4-Q399: Answer

Correct Answer: B

Continuous, role-specific training reinforced by phishing simulations and other exercises keeps security awareness current and effective.

D4-Q400: Security Incident Response Phases

Question

Which phase of incident response focuses on limiting the impact of an incident?

A. Preparation
B. Detection and analysis
C. Containment, eradication, and recovery
D. Post-incident activity

D4-Q400: Answer

Correct Answer: C

Containment limits the spread and impact of an incident; eradication removes the cause; recovery restores operations. Post-incident activity reviews lessons learned.

D4-Q401: Vulnerability Management

Question

Which is the MOST important step after identifying a critical vulnerability?

- A Document it and wait
- B Assess its risk and prioritize remediation based on business impact
- C Immediately shut down all systems
- D Blame the vendor

D4-Q401: Answer

Correct Answer: B

Vulnerabilities must be assessed in the context of business impact and exploitability, then prioritized for remediation based on risk.

D4-Q402: Data Loss Prevention

Question

What is the PRIMARY function of a data loss prevention (DLP) system?

- A Encrypt all data at rest
- B Detect and prevent unauthorized transfer of sensitive data
- C Back up all files
- D Manage user passwords

D4-Q402: Answer

Correct Answer: B

DLP monitors, detects, and blocks unauthorized transmission of sensitive data based on policy rules and data classification.

D4-Q403: Identity and Access Management

Question

Which principle is MOST fundamental to identity and access management?

- A Shared accounts for convenience
- B Least privilege and segregation of duties
- C Permanent access for all employees
- D Access without authentication

D4-Q403: Answer

Correct Answer: B

Least privilege and segregation of duties minimize access and prevent conflicts of interest, forming the foundation of IAM.

D4-Q404: Security Monitoring

Question

Which is the MOST important factor for effective security monitoring?

A. Buying the most expensive SIEM tool
B. Trained staff who can interpret and act on alerts
C. Collecting all possible logs without filtering
D. Monitoring only during business hours

D4-Q404: Answer

Correct Answer: B

Tools are only as effective as the people operating them. Trained analysts who can triage, investigate, and respond are essential.

D4-Q405: Patch Management

Question

What is the BEST practice for patch management?

- (A) Apply all patches immediately without testing
- (B) Test patches in a controlled environment before production deployment
- (C) Never apply patches to avoid disruption
- (D) Delegate patching entirely to vendors

D4-Q405: Answer

Correct Answer: B

Patches should be tested in a controlled environment before production rollout to avoid introducing new issues, while still applying them promptly.

D4-Q406: Cloud Shared Responsibility

Question

Under the cloud shared responsibility model, what is the customer ALWAYS responsible for?

- A Physical security of the data center
- B Data classification, access management, and configuration of customer-controlled components
- C Hypervisor patching
- D Network cabling

D4-Q406: Answer

Correct Answer: B

Customers retain responsibility for their data, access controls, and configuration of components within their control—regardless of cloud model.

D4-Q407: Third-Party Risk Assessment

Question

Which is the MOST important element of a third-party risk assessment?

- A The vendor's marketing materials
- B Evidence of security control effectiveness (e.g., SOC 2, ISO 27001)
- C The vendor's number of employees
- D The vendor's office location

D4-Q407: Answer

Correct Answer: B

Independent evidence of control effectiveness such as SOC 2 reports or ISO 27001 certification provides reliable assurance.

D4-Q408: Data Retention and Disposal

Question

What is the MOST important consideration for data disposal?

A. Delete files quickly to save space

B. Ensure data is unrecoverable in accordance with policy and regulation

C. Print all data before disposal

D. Archive everything forever

D4-Q408: Answer

Correct Answer: B

Secure disposal must render data unrecoverable, consistent with retention policies and regulatory requirements.

D4-Q409: Application Security Testing

Question

Which type of testing is MOST effective for finding security flaws in source code?

- A Penetration testing only
- B Static application security testing (SAST)
- C Vulnerability scanning of the network
- D User acceptance testing

D4-Q409: Answer

Correct Answer: B

SAST analyzes source code for security weaknesses without executing the application, making it effective for finding code-level flaws.

D4-Q410: Endpoint Protection

Question

Which is the MOST important element of endpoint protection in a modern enterprise?

A. Antivirus only
B. Layered defenses including EDR, patching, and configuration management
C. Firewall only
D. Password complexity only

D4-Q410: Answer

Correct Answer: B

Effective endpoint protection requires layered defenses—EDR, patching, configuration management, and user awareness—not any single tool.

D4-Q411: Network Segmentation

Question

What is the PRIMARY purpose of network segmentation?

A. To increase bandwidth

B. To limit the spread of attacks and protect sensitive segments

C. To simplify routing only

D. To reduce cable costs

D4-Q411: Answer

Correct Answer: B

Segmentation isolates sensitive assets and limits lateral movement, reducing the impact of a breach.

D4-Q412: Log Management

Question

Which is the MOST important consideration for log management?

- A Collecting logs and never reviewing them
- B Centralized, protected storage with timely review and retention per policy
- C Deleting logs immediately after generation
- D Storing logs only on the source system

D4-Q412: Answer

Correct Answer: B

Logs must be centrally collected, protected from tampering, reviewed in a timely manner, and retained per policy to support detection and forensics.

D4-Q413: Security Metrics

Question

Which is the BEST security metric for executive reporting?

- A Number of firewall rules
- B Trends in critical vulnerabilities, incidents, and control effectiveness relative to tolerance
- C Count of security policies
- D Number of antivirus definitions

D4-Q413: Answer

Correct Answer: B

Executives need trend-based metrics on critical vulnerabilities, incidents, and control effectiveness relative to tolerance—not operational counts.

D4-Q414: Business Continuity Testing

Question

What is the MOST effective way to validate a business continuity plan?

A. Reviewing the document only

B. Exercising the plan through tests and simulations and updating based on results

C. Filing it with regulators

D. Sharing it with the team

D4-Q414: Answer

Correct Answer: B

Plans must be exercised—through tabletop exercises, simulations, or full tests—and updated based on lessons learned to remain effective.

D4-Q415: Security Culture

Question

Which BEST describes the relationship between security culture and technical controls?

- A Technical controls alone are sufficient
- B Security culture and technical controls are complementary and both essential
- C Culture is irrelevant if controls are strong
- D Culture replaces technical controls

D4-Q415: Answer

Correct Answer: B

Strong technical controls can be undermined by poor culture (e.g., password sharing), and good culture cannot compensate for missing controls. Both are essential.

D1-Q516: Enterprise Risk Committee Charter

Question

An enterprise is forming a risk committee. Which element is MOST important to include in its charter?

A. The names of all risk owners

B. Its authority, scope, and reporting lines to the board

C. The tools it will use

D. Its meeting schedule

D1-Q516: Answer

Correct Answer: B

A charter must define authority, scope, and reporting relationships. Without these, the committee cannot provide effective oversight or enforce decisions.

D1-Q517: Business Unit Risk Reporting

Question

A business unit routinely submits risk reports late. What is the MOST likely governance root cause?

- A The reporting tool is inefficient
- B Unclear accountability and lack of consequences for late reporting
- C Too few risk reports required
- D Excessive regulation

D1-Q517: Answer

Correct Answer: B

Late reporting usually signals unclear accountability or missing consequences. Governance must define deadlines, owners, and escalation for noncompliance.

D1-Q518: Risk Appetite and Budget

Question

Management proposes a major investment outside the enterprise's risk appetite. What should the risk practitioner do FIRST?

A. Approve the investment
B. Escalate the misalignment to the risk owner and senior management
C. Ignore because investments are business decisions
D. Revise the risk appetite

D1-Q518: Answer

Correct Answer: B

The risk practitioner must escalate the misalignment. Approving or silently ignoring a decision outside appetite undermines governance.

D1-Q519: Risk Culture and KPIs

Question

Which KPI BEST reflects the health of an enterprise risk culture?

A. Number of risk assessments completed
B. Percentage of risk owners who completed their attestations on time
C. Number of risk policies published
D. Total spend on risk tools

D1-Q519: Answer

Correct Answer: B

Timely attestations indicate engaged risk owners and a functioning culture—not just completed paperwork.

D1-Q520: Board Members and Risk Detail

Question

A board member requests a list of every open vulnerability. What is the BEST response?

A. Provide the full list

B. Provide aggregated risk information aligned to appetite, with vulnerability detail available on request

C. Refuse the request

D. Delay until the annual report

D1-Q520: Answer

Correct Answer: B

Boards need aggregated risk against appetite. Raw vulnerability lists obscure judgment; aggregated views plus on-request detail support effective oversight.

D1-Q521: Risk Acceptance Authority

Question

Who should have authority to accept enterprise-level risk?

- A The risk practitioner
- B Business unit managers
- C Senior management or board, within delegated limits
- D External auditors

D1-Q521: Answer

Correct Answer: C

Risk acceptance authority must sit with management at the appropriate level, defined by limits and delegated formally.

D1-Q522: Emerging Risk Governance

Question

Which is the BEST governance mechanism for emerging risk?

- A Ignore until it crystallizes
- B Horizon scanning with periodic reporting to the risk committee
- C Delegate entirely to IT
- D Report only after incidents

D1-Q522: Answer

Correct Answer: B

Horizon scanning with periodic reporting ensures emerging risk is identified and assessed before it becomes a material exposure.

D1-Q523: Risk Awareness Program Failure

Question

A risk awareness program fails to change behavior. What is the MOST likely cause?

A. The intranet site is unattractive

B. Training is generic and not tied to employees' roles

C. Not enough posters

D. The program runs too often

D1-Q523: Answer

Correct Answer: B

Role-relevant training is essential for behavior change. Generic messages are ignored; tailored scenarios drive action.

D1-Q524: Risk Appetite Consistency

Question

An enterprise's risk appetite statement conflicts with several operational policies. What should be done FIRST?

A. Change the appetite statement

B. Align policies to appetite through review and revision

C. Ignore the inconsistency

D. Suspend operations

D1-Q524: Answer

Correct Answer: B

Policies must be consistent with appetite. Misalignment indicates a governance gap and can cause risk-taking outside tolerance.

D1-Q525: Third-Line Independence

Question

Internal audit reports to the CRO rather than the board. What is the MOST serious consequence?

A. Increased workload for audit

B. Reduced independence and objectivity of assurance

C. Higher audit costs

D. Slower reporting

D1-Q525: Answer

Correct Answer: B

Independence is foundational for third-line assurance. Reporting to a management function compromises objectivity and undermines trust in findings.

D1-Q526: Risk Culture and Incident Reporting

Question

The number of reported incidents falls sharply while the risk environment is worsening. What is the MOST likely interpretation?

A. Risk has decreased
B. A blame culture is suppressing reporting
C. Controls are effective
D. The reporting system is too easy to use

D1-Q526: Answer

Correct Answer: B

Falling reports in a worsening environment suggests suppression—classic symptom of a blame culture.

D1-Q527: Board Risk Education

Question

Board members have limited IT risk experience. What should the risk practitioner recommend FIRST?

A. Replace the board
B. Tailored risk education sessions for board members
C. Avoid board engagement
D. Hire an external auditor to educate the board

D1-Q527: Answer

Correct Answer: B

Tailored education builds board capability to oversee risk effectively—essential for governance.

D1-Q528: Risk Governance in Agile

Question

How should risk governance adapt in agile organizations?

A. Abandon risk governance

B. Embed risk decision-making in agile teams with clear thresholds and escalation

C. Centralize all risk decisions in a single committee

D. Delay risk assessment until release

D1-Q528: Answer

Correct Answer: B

Governance must be embedded so teams make risk-aware decisions within thresholds, escalating beyond them.

D1-Q529: Board IT Subcommittee

Question

Which BEST describes the role of a board-level IT risk subcommittee?

A. Execute controls

B. Provide focused oversight of IT-related risk to the full board

C. Perform vulnerability scans

D. Manage the IT budget

D1-Q529: Answer

Correct Answer: B

A subcommittee provides focused oversight of IT-related risk, reporting to the full board with sufficient expertise and attention.

D1-Q530: Risk Appetite Delegation

Question

When delegating risk appetite authority to business units, what is MOST important?

A. That units have documented thresholds and reporting obligations
B. That units never accept any risk
C. That authority is undocumented
D. That units are selected for low turnover

D1-Q530: Answer

Correct Answer: A

Delegated authority requires clear thresholds and reporting so the board can monitor aggregate exposure.

D1-Q531: Risk Ownership in Shared Services

Question

In a shared-services model, who owns the risk of a shared application?

A. The service provider

B. The business unit that consumes the service

C. A designated business owner with delegated accountability

D. No one

D1-Q531: Answer

Correct Answer: C

Shared services still require a designated business owner accountable for the risk and its response.

D1-Q532: Risk Culture and Leadership

Question

Which leadership behavior MOST strongly supports a healthy risk culture?

A. Punishing reporters of issues
B. Visible modeling of risk-aware decisions and open challenge
C. Delegating all risk decisions to auditors
D. Avoiding risk discussions

D1-Q532: Answer

Correct Answer: B

Leaders who model risk awareness and welcome challenge set the tone for a healthy risk culture.

D1-Q533: Risk Governance Metrics

Question

Which governance metric BEST indicates that risk owners are engaged?

A. Number of risk reports
B. Percentage of risk treatment plans on schedule
C. Number of software tools
D. Number of audits

D1-Q533: Answer

Correct Answer: B

On-time treatment plan execution shows owners are actively managing their risks—not just producing paperwork.

D1-Q534: Risk Governance and Business Changes

Question

A major acquisition is planned. What is the MOST important governance action FIRST?

- A Harmonize IT systems
- B Conduct pre-acquisition risk and governance due diligence
- C Reduce headcount
- D Standardize branding

D1-Q534: Answer

Correct Answer: B

Due diligence on the target's risk and governance maturity must come before integration decisions.

D1-Q535: Risk Reporting and Aggregation

Question

Business-unit reports omit cross-unit dependencies. What is the GREATEST consequence?

A. Reports are shorter
B. Aggregated risk underestimates exposure and may exceed appetite
C. Vendors are affected
D. Auditors are inconvenienced

D1-Q535: Answer

Correct Answer: B

Omitting dependencies hides correlated risk and can lead to underestimated exposure at the enterprise level.

D1-Q536: Governance in Outsourcing

Question

What should be established FIRST when outsourcing a critical function?

A. Contract pricing

B. Governance framework with accountability, reporting, and escalation

C. Vendor branding

D. SLA penalties

D1-Q536: Answer

Correct Answer: B

Governance (accountability, reporting, escalation) must be established to oversee outsourced risk—pricing and SLAs follow.

D1-Q537: Risk Governance and Crisis

Question

During a crisis, what is the MOST important governance action?

A. Assign blame

B. Activate the crisis governance structure with clear decision rights

C. Wait for auditors

D. Suppress communication

D1-Q537: Answer

Correct Answer: B

Crisis response requires clear decision rights and communication structures—pre-established for rapid, coordinated action.

D1-Q538: Board Engagement in Risk

Question

What is the BEST indicator that the board is meaningfully engaged in risk oversight?

A. Board meetings occur monthly

B. Board challenges risk assumptions and integrates risk into strategy decisions

C. Board receives extensive risk reports

D. Board has a risk committee

D1-Q538: Answer

Correct Answer: B

Meaningful engagement means challenge, integration of risk into strategy, and informed decisions—not just meetings and reports.

D1-Q539: Risk Appetite Breach Escalation

Question

A critical KRI breaches its threshold. What should happen FIRST?

- (A) Update the risk register months later
- (B) Notify the risk owner for assessment and action
- (C) Ignore until the annual review
- (D) Conduct a full external audit

D1-Q539: Answer

Correct Answer: B

Immediate notification of the risk owner is required so the breach is assessed and appropriate action initiated.

D1-Q540: Governance and Corporate Values

Question

How should corporate values inform risk governance?

- A They are unrelated
- B They set expectations for acceptable risk-taking behavior and shape risk appetite
- C They replace policies
- D They only matter to auditors

D1-Q540: Answer

Correct Answer: B

Corporate values shape acceptable risk-taking behavior and inform risk appetite, creating coherence between strategy and behavior.

D2-Q541: New Cloud Migration Assessment

Question

Before migrating a critical application to a cloud provider, what must be assessed FIRST?

A. The provider's marketing material

B. Data classification, regulatory obligations, and provider assurance

C. The provider's stock price

D. The number of provider employees

D2-Q541: Answer

Correct Answer: B

Cloud assessment must first consider data classification, regulatory obligations, and provider assurance evidence.

D2-Q542: Merger Risk Assessment

Question

During a merger, which risk is MOST commonly overlooked?

A. Technology incompatibility
B. Cultural and governance misalignment
C. Branding conflicts
D. Office locations

D2-Q542: Answer

Correct Answer: B

Cultural and governance misalignment is consistently the most overlooked integration risk.

D2-Q543: Risk Assessment for AI

Question

What unique risk must be assessed FIRST when deploying AI?

A. Vendor stability

B. Model transparency, bias, and explainability

C. Hardware cost

D. Office location of developers

D2-Q543: Answer

Correct Answer: B

AI-specific risk (bias, explainability, model behavior) must be assessed first, given the unique harms AI can cause.

D2-Q544: Insider Threat Assessment

Question

What is the MOST important factor in assessing insider threat risk?

- A Number of employees
- B Access privileges combined with behavioral indicators
- C Office layout
- D Number of audits

D2-Q544: Answer

Correct Answer: B

Insider risk is driven by access privilege and behavioral signals—the combination is the key assessment factor.

D2-Q545: Risk Assessment for IoT

Question

What is the MOST critical assessment focus for IoT devices?

A. Marketing of the IoT vendor

B. Default credentials, update capability, and network exposure

C. Number of devices

D. Power consumption

D2-Q545: Answer

Correct Answer: B

IoT default credentials, lack of update mechanisms, and insecure exposure are the dominant sources of risk.

D2-Q546: Risk Assessment for OT

Question

For operational technology, which risk is MOST unique?

- A Password length
- B Physical safety consequences of a cyber event
- C Office ergonomics
- D Vendor branding

D2-Q546: Answer

Correct Answer: B

OT risk can produce physical safety and environmental consequences—unlike traditional IT risk.

D2-Q547: Risk Scenario for Ransomware

Question

Which is the BEST-formed ransomware risk scenario?

A. "Ransomware might happen"

B. "Phishing leads to ransomware that encrypts file shares, halting operations for 48 hours"

C. "Ransomware is bad"

D. "We need better security"

D2-Q547: Answer

Correct Answer: B

A well-formed scenario identifies cause (phishing), event (ransomware), and consequence (operations halted).

D2-Q548: Risk Assessment for Supply Chain

Question

Which consideration is MOST important in supply chain risk assessment?

- A Number of suppliers
- B Concentration, single points of failure, and contractual flow-down
- C Office locations
- D Vendor branding

D2-Q548: Answer

Correct Answer: B

Concentration and contractual flow-down of security requirements determine supply chain resilience.

D2-Q549: Risk Assessment for Mergers

Question

Which artifact is MOST valuable during MA risk assessment?

A. Marketing deck
B. Target's risk register, control assessments, and incident history
C. Brand style guide
D. Office lease agreements

D2-Q549: Answer

Correct Answer: B

The target's risk register, control assessments, and incident history reveal its risk posture and inherited exposures.

D2-Q550: Third-Party Assessment Depth

Question

Which factor MOST determines depth of a third-party assessment?

A. Vendor size

B. Criticality of the service and sensitivity of data involved

C. Vendor location

D. Length of the contract

D2-Q550: Answer

Correct Answer: B

Assessment depth should scale with criticality and data sensitivity—not contract size or vendor location.

D2-Q551: Risk Assessment and Business Impact

Question

Which is the MOST important output of a BIA for risk assessment?

- A Vendor list
- B Critical processes, RTOs, RPOs, and impact over time
- C User survey results
- D Technology inventory

D2-Q551: Answer

Correct Answer: B

BIA outputs critical processes, recovery targets, and impact over time—essential inputs for prioritizing risk.

D2-Q552: Risk Register for AI Systems

Question

What additional risk register content is needed for AI systems?

A. Vendor name only

B. Model purpose, training data, and explainability information

C. Code lines of code

D. Office location

D2-Q552: Answer

Correct Answer: B

AI risk register entries require model purpose, training data provenance, and explainability records.

D2-Q553: Assessment of New Tech

Question

When introducing a novel technology, what should be done FIRST?

- (A) Pilot deployment to all users
- (B) Threat modeling and risk assessment
- (C) Purchase licenses
- (D) Announce to media

D2-Q553: Answer

Correct Answer: B

Threat modeling and risk assessment of novel technology should precede any deployment.

D2-Q554: Risk Assessment Iteration

Question

How often should the risk register be fully reassessed?

A. Never

B. At a cadence matched to the rate of change in the environment and criticality

C. Only after incidents

D. Only when auditors ask

D2-Q554: Answer

Correct Answer: B

Reassessment cadence should be proportional to the pace of change and the criticality of what is assessed.

D2-Q555: Assessment of Business Changes

Question

What should trigger an immediate ad hoc risk assessment?

- A. A new hire
- B. A significant business change (e.g., new product, geography, or technology)
- C. A new auditor
- D. A vendor rebrand

D2-Q555: Answer

Correct Answer: B

Significant business changes alter risk exposure and require prompt reassessment.

D2-Q556: Risk Assessment and Insurance

Question

How does risk assessment inform insurance decisions?

- A It has no role
- B It quantifies exposure so insurance limits and deductibles can be set
- C It only matters to vendors
- D It should be ignored

D2-Q556: Answer

Correct Answer: B

Risk assessment quantifies exposure, enabling appropriate insurance limits, deductibles, and coverage selection.

D2-Q557: Risk Assessment and Business Continuity

Question

Which is the PRIMARY link between risk assessment and business continuity?

A. Vendor selection

B. Risk assessment identifies threats and impacts; BIA quantifies recovery needs; together they drive BC planning

C. Neither is related

D. Both are optional

D2-Q557: Answer

Correct Answer: B

Risk assessment identifies threats and impacts; BIA quantifies recovery needs. Combined, they inform BC strategy and testing.

D2-Q558: Risk Assessment for Cloud Misconfiguration

Question

What is the leading cloud risk category?

A. Provider bankruptcies
B. Customer misconfiguration of cloud resources
C. Data center weather events
D. Provider stock volatility

D2-Q558: Answer

Correct Answer: B

Customer misconfiguration (public buckets, weak IAM) is consistently the leading cloud risk.

D2-Q559: Risk Assessment and Maturity

Question

How does risk management maturity affect risk assessment quality?

- A Maturity has no effect
- B Higher maturity yields more consistent, documented, and repeatable assessments
- C Lower maturity yields better assessments
- D Maturity equals zero risk

D2-Q559: Answer

Correct Answer: B

Maturity correlates with consistent, documented, and repeatable assessment practices.

D2-Q560: Assessment of Third-Party Concentration

Question

Why is vendor concentration a key risk assessment concern?

A. Vendor branding

B. A single provider disruption can affect multiple critical services simultaneously

C. Vendor office location

D. Vendor marketing

D2-Q560: Answer

Correct Answer: B

Concentration creates correlated exposure—one provider failure can disrupt multiple services.

D2-Q561: Risk Assessment and Regulatory Change

Question

A new privacy regulation passes. What is the FIRST risk assessment action?

- A Update policies immediately
- B Assess impact on business processes, data flows, and existing controls
- C Ignore until enforcement
- D Announce compliance publicly

D2-Q561: Answer

Correct Answer: B

Impact assessment comes first—policies and controls should follow an understanding of the regulation's effects.

D2-Q562: Risk Assessment and Scenario Planning

Question

What is the PRIMARY benefit of scenario planning in risk assessment?

A. It replaces the risk register

B. It surfaces non-obvious exposures and dependencies

C. It eliminates risk

D. It satisfies regulators

D2-Q562: Answer

Correct Answer: B

Scenario planning surfaces exposures and dependencies that checklists miss.

D2-Q563: Risk Assessment and Insider Risk

Question

Which is the MOST effective control for insider risk after assessment?

- A Firewalls
- B Least privilege combined with monitoring and behavioral analytics
- C Antivirus
- D Strong passwords only

D2-Q563: Answer

Correct Answer: B

Insider risk is best managed through least privilege plus monitoring and behavioral analytics.

D2-Q564: Risk Assessment and Change

Question

Why must risk assessment be repeated after significant change?

A. To keep auditors busy

B. Because change alters exposure, dependencies, and control effectiveness

C. Because regulators require it

D. Because vendors ask

D2-Q564: Answer

Correct Answer: B

Change alters exposure and control effectiveness—reassessment is required to maintain accurate risk understanding.

D2-Q565: Risk Assessment Output for Board

Question

Which is the MOST valuable risk assessment output for the board?

- A Raw vulnerability lists
- B Aggregated risk against appetite with clear recommendations
- C Detailed network diagrams
- D All technical findings

D2-Q565: Answer

Correct Answer: B

The board needs aggregated risk vs. appetite with clear recommendations—technical detail obscures oversight.

D3-Q566: Cloud Incident Response

Question

What is MOST important to establish with a cloud provider before an incident?

A. Marketing contacts
B. Incident notification and forensic cooperation requirements
C. Stock price disclosure
D. Office locations

D3-Q566: Answer

Correct Answer: B

Incident notification SLAs and forensic cooperation must be contractually established in advance.

D3-Q567: Ransomware Response

Question

What is the MOST important FIRST response action to ransomware?

A. Pay the ransom

B. Isolate affected systems and notify the incident response team

C. Communicate to press

D. Blame employees

D3-Q567: Answer

Correct Answer: B

Containment (isolation) and IR activation precede all other actions—including ransom decisions.

D3-Q568: Third-Party Breach Response

Question

A vendor reports a breach. What should the enterprise do FIRST?

- (A) Terminate the contract
- (B) Activate incident coordination, assess data exposure, and notify regulators as required
- (C) Ignore
- (D) Announce to press

D3-Q568: Answer

Correct Answer: B

Coordination, data-exposure assessment, and required notifications are the correct immediate actions.

D3-Q569: Insider Incident Response

Question

For a suspected insider data theft, what is MOST critical FIRST?

A. Confront the employee

B. Preserve evidence and involve legal/HR, avoiding tipping off the suspect

C. Ignore

D. Announce to press

D3-Q569: Answer

Correct Answer: B

Preserving evidence and coordinating with legal/HR—without tipping off—is essential to investigation success.

D3-Q570: Business Continuity Activation

Question

When should a BCP be activated?

- A. Whenever any incident occurs
- B. When a disruption exceeds defined activation criteria and thresholds
- C. Only after regulators demand it
- D. Only annually

D3-Q570: Answer

Correct Answer: B

Activation should follow predefined criteria and thresholds—not every incident warrants full continuity activation.

D3-Q571: Communications During Crisis

Question

What is MOST important about crisis communications?

A. Speeding to press without facts

B. Preapproved channels, spokespeople, and templates with factual updates

C. Silence

D. Blaming vendors

D3-Q571: Answer

Correct Answer: B

Preapproved channels, spokespeople, and templates ensure clear, factual, and controlled communications.

D3-Q572: Risk Treatment for Legacy Systems

Question

A critical legacy system cannot be patched. What is the BEST response?

- A Ignore
- B Compensating controls (segmentation, monitoring) with documented acceptance
- C Turn off the system
- D Blame the vendor

D3-Q572: Answer

Correct Answer: B

Compensating controls plus documented acceptance are appropriate when patching is infeasible.

D3-Q573: Risk Response for Remote Work

Question

What is the MOST important remote-work risk response?

A. VPN only

B. Layered defenses: device management, zero trust, MFA, and monitoring

C. Password changes only

D. Buying new laptops

D3-Q573: Answer

Correct Answer: B

Remote work requires layered defenses—device management, zero trust, MFA, and monitoring—not a single control.

D3-Q574: Risk Response for Shadow IT

Question

What is the BEST response to Shadow IT?

A. Punish users

B. Discover, assess, and either secure or provide approved alternatives

C. Ignore

D. Block everything

D3-Q574: Answer

Correct Answer: B

Discovery plus assessment and approved alternatives addresses the underlying need—purely blocking often fails.

D3-Q575: Response to Vulnerability Exploit

Question

A critical vulnerability is being actively exploited. What should happen FIRST?

A. Wait for the next patch cycle

B. Apply emergency mitigation (compensating controls or emergency patch)

C. Ignore

D. Announce to press

D3-Q575: Answer

Correct Answer: B

Active exploitation requires emergency mitigation—not waiting for the next patch cycle.

D3-Q576: Risk Response for MA

Question

What is the MOST important post-merger risk response action?

- A Rebrand quickly
- B Integrate governance, controls, and risk registers
- C Lay off employees
- D Standardize office furniture

D3-Q576: Answer

Correct Answer: B

Integrating governance and controls is essential to realize the value of the merger and manage inherited risk.

D3-Q577: Risk Response for AI

Question

What is the MOST important AI risk response control?

A. Marketing

B. Human oversight, monitoring, and bias testing

C. Faster hardware

D. Office location

D3-Q577: Answer

Correct Answer: B

Human oversight, ongoing monitoring, and bias testing are essential AI risk controls.

D3-Q578: Risk Response for Data Loss

Question

What is the MOST effective layered defense for data loss?

- A Firewall alone
- B DLP, encryption, access controls, and monitoring together
- C Antivirus alone
- D Password changes

D3-Q578: Answer

Correct Answer: B

DLP, encryption, access controls, and monitoring together form an effective layered defense.

D3-Q579: Risk Response and Vendor Exit

Question

What is MOST important in a vendor exit strategy?

A. Branding
B. Data return/destruction, transition support, and continuity provisions
C. Marketing
D. Office location

D3-Q579: Answer

Correct Answer: B

Exit strategies must specify data return/destruction, transition support, and continuity provisions.

D3-Q580: Risk Response and Regulatory Investigation

Question

Regulators begin an investigation. What should happen FIRST?

- A Speak publicly
- B Engage legal counsel and preserve evidence
- C Delete records
- D Blame the vendor

D3-Q580: Answer

Correct Answer: B

Legal counsel engagement and evidence preservation are the correct first steps in a regulatory investigation.

D3-Q581: Risk Response for Misconfiguration

Question

The leading cause of cloud breaches is misconfiguration. What is the BEST response?

A. Ignore

B. Baseline configurations, automated compliance scanning, and change control

C. Manual review annually

D. Password changes

D3-Q581: Answer

Correct Answer: B

Baselines plus automated scanning and change control address misconfiguration at scale.

D3-Q582: Risk Response for Third Party

Question

What is the MOST effective control for third-party risk?

A. Vendor marketing

B. Contractual requirements plus independent assurance and monitoring

C. Vendor size

D. Vendor location

D3-Q582: Answer

Correct Answer: B

Contractual controls plus independent assurance and ongoing monitoring constitute the strongest third-party control.

D3-Q583: Response to Breach Notification

Question

After a breach notification, what is the MOST important action?

A. Hide it

B. Assess scope, notify as required, and implement lessons learned

C. Blame employees

D. Delay

D3-Q583: Answer

Correct Answer: B

Scope assessment, required notifications, and lessons learned are the correct post-breach actions.

D3-Q584: Risk Response and Business Change

Question

After a major business change, what should be revisited FIRST?

A. Brand guidelines
B. Risk assessment and treatment plan alignment
C. Office layout
D. Marketing

D3-Q584: Answer

Correct Answer: B

Risk assessments and treatment plans must be revisited and realigned after significant business change.

D3-Q585: Risk Response and Residual Risk

Question

Residual risk remains above tolerance after treatment. What should happen?

A. Ignore
B. Escalate to the risk owner for further treatment or formal acceptance
C. Adjust the assessment
D. Blame the vendor

D3-Q585: Answer

Correct Answer: B

Residual risk above tolerance must be escalated for further treatment or formal acceptance by the appropriate owner.

D3-Q586: Risk Response and Insurance Renewal

Question

Before renewing cyber insurance, what is MOST important?

- A Compare premium only
- B Confirm coverage aligns to current risk exposure and control posture
- C Negotiate faster payment
- D Ignore exclusions

D3-Q586: Answer

Correct Answer: B

Coverage should be reviewed against current exposure and controls—premium alone is an insufficient decision basis.

D3-Q587: Risk Response and Crisis

Question

During a crisis, what is MOST important about decision-making?

- A Slow and hierarchical
- B Clear delegated authority and pre-approved playbooks
- C Consensus at every step
- D Avoid communication

D3-Q587: Answer

Correct Answer: B

Crisis decisions require pre-delegated authority and playbooks to act quickly and coherently.

D3-Q588: Risk Response and Lessons Learned

Question

After an incident, what is MOST important about lessons learned?

- A Blame individuals
- B Systematically update policies, controls, and playbooks
- C File and forget
- D Announce publicly

D3-Q588: Answer

Correct Answer: B

Lessons learned must translate into updates to policy, control, and playbooks—not blame.

D3-Q589: Risk Response and Business Continuity Testing

Question

Which test is MOST valuable for a newly created BCP?

A. Document review
B. Tabletop exercise followed by targeted technical tests
C. Marketing review
D. No testing

D3-Q589: Answer

Correct Answer: B

Tabletop exercises plus targeted technical tests validate and improve the plan.

D3-Q590: Risk Response and Shared Responsibility

Question

Under the shared responsibility model, what must be defined FIRST?

A. Pricing

B. Which controls each party is responsible for

C. Marketing

D. Office location

D3-Q590: Answer

Correct Answer: B

Explicit definition of which controls belong to which party is essential to prevent gaps and overlaps.

D3-Q591: Risk Response and Compliance

Question

What is the MOST important compliance risk response control?

A. Marketing

B. Continuous compliance monitoring against regulatory obligations

C. Annual audit alone

D. Password changes

D3-Q591: Answer

Correct Answer: B

Continuous compliance monitoring provides real-time assurance; annual audits alone leave gaps.

D3-Q592: Risk Response for Supply Chain

Question

What is the most important supply chain risk response?

- A Vendor branding
- B Contractual security requirements plus assurance and diversification
- C Vendor location
- D Vendor size

D3-Q592: Answer

Correct Answer: B

Contractual controls, independent assurance, and diversification reduce supply chain risk materially.

D3-Q593: Risk Response and Third-Party Access

Question

What is the most important control for third-party access to systems?

- A Password complexity alone
- B Least privilege, MFA, monitoring, and timely revocation
- C Marketing
- D Office location

D3-Q593: Answer

Correct Answer: B

Least privilege, MFA, monitoring, and timely revocation are the essential controls for third-party access.

D3-Q594: Risk Response and Regulatory Penalties

Question

A regulator proposes a significant fine. What is the BEST response?

- A Ignore
- B Engage counsel, remediate root causes, and negotiate remediation credit where possible
- C Blame vendors
- D Announce to press without counsel

D3-Q594: Answer

Correct Answer: B

Counsel engagement, root-cause remediation, and negotiating remediation credit are the correct steps.

D3-Q595: Risk Response and Continuous Improvement

Question

What is the MOST important continuous improvement activity after a risk event?

A. Blame

B. Update risk assessments, controls, and playbooks based on outcomes

C. Forget

D. Increase premiums

D3-Q595: Answer

Correct Answer: B

Systematic updates to assessments, controls, and playbooks embed learning into the risk program.

D4-Q596: Securing Remote Access

Question

What is the MOST important control for remote access security?

- A Long passwords
- B Zero trust with MFA and least privilege
- C Single VPN
- D Office location

D4-Q596: Answer

Correct Answer: B

Zero trust with MFA and least privilege—not perimeter-only controls—secures remote access.

D4-Q597: Protecting Data at Rest

Question

What is the most effective control for data at rest?

- A Hashing
- B Encryption with strong key management
- C Password changes
- D Firewall

D4-Q597: Answer

Correct Answer: B

Encryption with strong key management protects data at rest; hashing does not provide confidentiality.

D4-Q598: Protecting Data in Transit

Question

What is the most effective control for data in transit?

- A Hashing
- B TLS with strong cipher suites
- C Antivirus
- D Password changes

D4-Q598: Answer

Correct Answer: B

TLS with strong cipher suites is the standard control for protecting data in transit.

D4-Q599: Identity Provider Compromise

Question

What is the GREATEST risk if an identity provider is compromised?

- A Increased workload
- B Widespread access compromise across federated systems
- C Vendor branding
- D Office location

D4-Q599: Answer

Correct Answer: B

A compromised identity provider can enable access to all federated systems—an enterprise-wide single point of failure.

D4-Q600: Application Security

Question

What is the most effective way to reduce application-level vulnerabilities?

- A Weekly password changes
- B Secure coding practices, SAST/DAST, and dependency management
- C Firewall only
- D Office location

D4-Q600: Answer

Correct Answer: B

Secure coding practices, SAST/DAST, and dependency management reduce application vulnerabilities at scale.

D4-Q601: Protecting Against Phishing

Question

What is the MOST effective technical control against phishing?

A. Longer passwords
B. DMARC, URL filtering, and MFA on accounts
C. Firewalls only
D. Office location

D4-Q601: Answer

Correct Answer: B

DMARC, URL filtering, and MFA materially reduce phishing impact and credential compromise.

D4-Q602: Data Classification Challenge

Question

What is the MAIN challenge in data classification?

- A Too few files
- B Consistency across systems and lifecycle stages
- C Encryption
- D Firewalls

D4-Q602: Answer

Correct Answer: B

Maintaining consistent classification across systems and lifecycle stages is the primary challenge.

D4-Q603: Third-Party Access Control

Question

What is the most important control for third-party access?

A. Long contracts

B. Time-bound, least-privilege access with monitoring and timely revocation

C. Marketing

D. Office location

D4-Q603: Answer

Correct Answer: B

Time-bound, least-privilege access with monitoring and revocation is essential for third-party access security.

D4-Q604: Cloud Misconfiguration

Question

What is the most effective way to reduce cloud misconfiguration risk?

- A Longer passwords
- B Infrastructure-as-code baselines with automated scanning
- C Firewalls only
- D Office location

D4-Q604: Answer

Correct Answer: B

IaC baselines with automated scanning reduce misconfiguration at scale more effectively than manual review.

D4-Q605: Security Awareness Measurement

Question

What is the BEST way to measure security awareness effectiveness?

- A Number of emails sent
- B Simulation results, reporting rates, and behavioral metrics over time
- C Posters distributed
- D Office location

D4-Q605: Answer

Correct Answer: B

Simulation results, reporting rates, and behavioral metrics over time are the best evidence of awareness effectiveness.

D4-Q606: Data Breach Response

Question

What is the FIRST action after discovering a breach?

- A Announce to press
- B Contain the breach and activate incident response
- C Blame employees
- D Delay

D4-Q606: Answer

Correct Answer: B

Containment and IR activation come first—disclosure and other steps follow assessment.

D4-Q607: Insider Threat Program

Question

What is the most important element of an insider threat program?

- A Marketing
- B Cross-functional detection, investigation, and legal coordination
- C Firewall alone
- D Office location

D4-Q607: Answer

Correct Answer: B

Insider threat programs require coordinated detection, investigation, and legal/HR involvement.

D4-Q608: Patch Management Strategy

Question

What is the MOST important factor in patch management strategy?

A. Marketing

B. Risk-based prioritization with testing and rollback

C. Fastest patch application

D. Office location

D4-Q608: Answer

Correct Answer: B

Risk-based prioritization with testing and rollback balances speed and stability.

D4-Q609: Log Management Program

Question

What is the MOST important element of a log management program?

A. Volume of logs
B. Centralized, protected, and actively reviewed logs per policy
C. Marketing
D. Office location

D4-Q609: Answer

Correct Answer: B

Logs must be centralized, protected, and actively reviewed—collection alone provides no value.

D4-Q610: Security Architecture Review

Question

What is the PRIMARY purpose of a security architecture review?

- (A) Marketing
- (B) Identify design gaps and misalignments with business and risk requirements
- (C) Office location
- (D) Vendor branding

D4-Q610: Answer

Correct Answer: B

Security architecture reviews identify design gaps and misalignment with business and risk requirements.

D4-Q611: Multi-Cloud Security

Question

What is the MOST important multi-cloud security consideration?

- A Vendor branding
- B Consistent policy, identity, and monitoring across clouds
- C Office location
- D Vendor size

D4-Q611: Answer

Correct Answer: B

Consistent policy, identity, and monitoring prevent gaps and inconsistencies in multi-cloud environments.

D4-Q612: Artificial Intelligence Security

Question

What is a key AI-specific security risk?

- A Marketing
- B Adversarial inputs and data poisoning
- C Office location
- D Vendor branding

D4-Q612: Answer

Correct Answer: B

AI is uniquely exposed to adversarial inputs and data poisoning—risks absent in traditional systems.

D4-Q613: OT Security

Question

What is the MOST important OT security consideration?

A. Marketing
B. Safety and availability with strict change control
C. Office location
D. Vendor branding

D4-Q613: Answer

Correct Answer: B

OT security prioritizes safety and availability with strict change control—unlike IT where confidentiality is often paramount.

D4-Q614: Third-Party SOC Reports

Question

Which SOC report provides the STRONGEST assurance of ongoing control effectiveness?

A. SOC 1 Type I
B. SOC 2 Type II
C. Marketing
D. SOC 3

D4-Q614: Answer

Correct Answer: B

SOC 2 Type II reports on control effectiveness over a period—the strongest assurance for security controls.

D4-Q615: Security Program Metrics

Question

Which security program metric is MOST valuable for executives?

A. Number of firewall rules

B. Trends in critical risks, incidents, and control effectiveness vs. tolerance

C. Office location

D. Marketing

D4-Q615: Answer

Correct Answer: B

Executives need trends in critical risks, incidents, and control effectiveness relative to tolerance—not operational counts.